Adaptive Multi-Stage Behavioural Progression Architecture For Early Detection Of SIP Toll Fraud

K.M.U.P. Kosgoda
(Reg. No.: MS24913188)

A THESIS
SUBMITTED TO
SRI LANKA INSTITUTE OF INFORMATION TECHNOLOGY
IN PARTIAL FULFILMENT OF THE REQUIREMENTS
FOR THE DEGREE OF
MASTER OF SCIENCE IN INFORMATION SYSTEMS

November 2026

I certify that I have read this thesis and that in my opinion it is fully adequate, in scope and in quality, as a thesis for the degree of Master of Science.

_____

Dr. Nimal Rathnayake

Approved for MSc. Research Project:

_____

MSc in Information Systems Programme Co-ordinator, SLIIT

Approved for MSc:

_____

Head of Graduate Studies, FoC, SLIIT

DECLARATION

This is to certify that the work is entirely my own and not of any other person, unless explicitly acknowledged (including citation of published and unpublished sources). The work has not previously been submitted in any form to the Sri Lanka Institute of Information Technology or to any other institution for assessment for any other purpose.

Sign: .....

K.M.U.P. Kosgoda

Date: ……..

ABSTRACT

Adaptive Multi-Stage Behavioural Progression Architecture For Early Detection Of SIP Toll Fraud

K.M.U.P. Kosgoda

MSc. in Information Systems

Supervisor: Dr. Nimal Rathnayake

November 2026

This thesis develops and evaluates a SIP behavioural progression prototype using an Asterisk PBX and a separate SIPp generator. The detector evolved from request counts to confirmed authentication failures and linked registration and call events. V6 flagged six simulated attack cases and one benign control in a twelve-case development set. A frozen causal logistic model did not distinguish matched authorized and simulated-unauthorized roles. A later native and external deployment pilot verified seven cases and twenty-one isolated calls across five online stage categories. The final extension predefined account, destination and recovery permissions before twelve fresh experiments. All cases passed independent packet, authentication-log, CDR and cleanup checks, including nine answered calls. V6 produced TP=5, FP=2, TN=4 and FN=1. Contextual review produced TP=5, FP=1, TN=5 and FN=1, increasing balanced accuracy from 75.0% to 83.3% on this small controlled set. However, pre-call warnings decreased from four of five simulated-role call cases to two of five. A five-failure simple baseline warned earlier than V6. Four separate REGISTER-only controls also verified. The contribution is auditable progression and permission-conditioned review with an explicit ambiguity boundary. Allowed-policy abuse remains indistinguishable in a matched case, and false-alert reduction can reduce warning coverage. These results do not establish operational fraud accuracy, autonomous adaptation, causal overhead or production readiness.

Keywords: SIP security, VoIP fraud detection, toll fraud, behavioural progression, early detection, CDR analytics, risk scoring.

ACKNOWLEDGEMENT

I would like to express my sincere gratitude to my supervisor, Dr. Nimal Rathnayake, for his guidance, constructive feedback, and support throughout this research. I also acknowledge the academic staff of the Sri Lanka Institute of Information Technology for the knowledge and resources provided during the MSc programme. I am grateful to my colleagues, friends, and family for their encouragement and patience while I designed the experimental environment, conducted repeated tests, and prepared this thesis. Any remaining errors or limitations in this work are my own.

TABLE OF CONTENTS

DECLARATION ii
ABSTRACT iii
ACKNOWLEDGEMENT iv
List of Figures viii
List of Tables ix
List of Abbreviations x
Chapter 1 Introduction 1
1.1 Background 1
1.1.1 From SIP observations to research claims 1
1.2 Research Problem 3
1.2.1 Threat model and authorization boundary 3
1.3 Research Gap 4
1.4 Research Aim 4
1.5 Research Objectives 5
1.6 Research Questions and Hypotheses 6
1.7 Scope of the Study 7
1.7.1 Interpretation of an early warning 7
1.8 Significance and Contributions 8
1.8.1 Contribution and evidence expectations 8
1.9 Thesis Organization 9
Chapter 2 Literature Review 10
2.1 Introduction 10
2.2 SIP and VoIP Security Foundations 10
2.2.1 Transaction semantics and evidence quality 10
2.3 SIP Toll Fraud and Behavioural Progression 12
2.3.1 Position relative to multistage toll fraud research 12
2.4 Real-Time Fraud Detection 13
2.4.1 Event correlation and the meaning of real time 13
2.5 Stateful and Protocol-Aware SIP Detection 15
2.5.1 Stateful inspection and progression representation 15
2.6 CDR and Telecom Behavioural Analytics 16
2.6.1 What call records add to signalling evidence 16
2.6.2 Graph models and the scale of contextual evidence 18
2.7 Machine Learning for SIP Attack Detection 19
2.7.1 Matching the learning task to the fraud question 19
2.7.2 Learning validity and deployment interpretation 20
2.8 Comparison of Selected Related Work 21
2.9 Research Gap and Positioning 22
2.9.1 Critical synthesis and design requirements 22
2.10 Conceptual Framework 23

2.10.1 Information boundaries in the conceptual framework 24
2.11 Chapter Summary 25
Chapter 3 Research Methodology 26
3.1 Design science process and evaluation sequence 26
3.2 Laboratory Configuration and Evaluation History 27
3.3 Sampling Units and Evidence Families 28
3.3.1 Threat model and observational units 28
3.4 Independent Ground Truth and Acceptance Gates 30
3.4.1 Evidence acceptance and failure preservation 30
3.5 Temporally Available Features and Model Separation 31
3.5.1 Inference specification and experimental separation 32
3.5.2 Feature availability and model freezing 33
3.6 Distinct Timing Measures 34
3.6.1 Timing interpretation and observation boundaries 34
3.7 Classification and Operational Evaluation 35
3.7.1 Classification definitions and complete case reporting 35
3.8 Validity and Ethics 36
3.8.1 Validity protections and remaining uncertainty 37
3.9 Predeclared Permission Context and Common Evaluation 37
3.9.1 Fresh comparison protocol and information separation 38
Chapter 4 System Design and Implementation 40
4.1 Detector Evolution and Rationale 40
4.2 Confirmed Authentication and Reconnaissance 40
4.2.1 Transaction matching and rejection confirmation 40
4.2.2 Entity histories and stage state 42
4.3 Recovery and Linked Call Progression 43
4.3.1 Call attempts completion and distinct call counting 43
4.4 Lightweight Review Priority 45
4.4.1 Causal score interpretation and review metadata 45
4.5 Internal and External Realizations 46
4.5.1 Deployment paths and comparable functionality 46
4.6 Reproducibility and Implementation Boundaries 47
4.6.1 Reproducibility records and limits of replay 48
4.7 Permission Layer and Causal Replay Implementation 49
4.7.1 Causal prefix evaluation and information leakage controls 49
4.7.2 Permission outcomes and actionable review semantics 50
4.7.3 Implementation checks and bounded assurance 51
Chapter 5 Results and Discussion 53
5.1 Earlier Loopback Baseline and Boundary Findings 53
5.1.1 Interpretation of the successive evaluation families 54
5.2 Registered Scenario Coverage 55
5.3 Common Onset Archived Timing 55

5.3.1 Meaning of an early warning advantage 56
5.4 Frozen Causal Model Evaluation 57
5.4.1 What the matched profiles reveal about machine learning 58
5.5 Live Integration and Shared Authentication Delivery 59
5.6 Call Setup and Resource Pilot 60
5.6.1 Operational interpretation of the deployment observations 62
5.7 Research Questions and Hypotheses 63
5.8 Limitations and Exploratory Extensions 63
5.9 Later Five Stage Deployment Pilot 64
5.10 Fresh Permission Context Comparison 65
5.10.1 Why the context comparison changes particular decisions 66
5.10.2 Interpreting coverage together with warning lead 68
5.11 Fresh REGISTER Controls and Reproducibility 69
5.11.1 Reproducibility and the limits of repeated evidence 70
Chapter 6 Conclusion and Future Work 72
6.1 Conclusions 72
6.1.1 Scope of the final contribution 72
6.2 Objective Coverage 73
6.2.1 Relationship between objective coverage and expected benefit 74
6.3 Future Work 74
6.3.1 Design of the next validation study 75
References 77
Appendices 79
A Progression Logic and Causal Scoring 79
B Frozen Model Configuration 80
C Evidence and Source Index 81
D Reproducibility Checksums 82

List of Figures

Figure 2.1 Conceptual detection architecture 23
Figure 3.1 Laboratory evidence and early scoring pipeline 28
Figure 3.2 Scenario generation validation and frozen evaluation 31
Figure 4.1 Confirmed authentication failure and recovery logic 42
Figure 4.2 Recovery call attempts and independent completion evidence 44
Figure 4.3 Shared authentication deployment paths and observation endpoints 47
Figure 4.4 Frozen stage logic and independent context in the common evaluator 50
Figure 5.1 Frozen model scores on five matched profiles 58
Figure 5.2 Individual call setup times and per case medians 61
Figure 5.3 False alerts and missed assigned roles in twelve fresh cases 65
Figure 5.4 Pre call coverage with missed and at attempt cases retained 68

List of Tables

Table 1.1 Research objectives and evaluation focus 5
Table 2.1 Comparison of selected related work 21
Table 3.1 Later two Pi laboratory 27
Table 3.2 Evidence families and permitted interpretation 29
Table 3.3 Features available at the scoring event 31
Table 3.4 Timing endpoints used in the evaluation 34
Table 3.5 Independent laboratory permission matrix 38
Table 4.1 Research detector evolution 40
Table 5.1 Historical loopback scenario timing 53
Table 5.2 Historical loopback event metrics 53
Table 5.3 F-series scenario confusion counts and metrics 55
Table 5.4 Archived seconds to first alert from a common onset 55
Table 5.5 Opposite role scores from the frozen causal model 57
Table 5.6 Shared authentication observed alert availability 60
Table 5.7 Accepted call setup cases 60
Table 5.8 Within block setup differences relative to OFF 61
Table 5.9 Process observations during accepted call traffic 61
Table 5.10 Evidence based answers and remaining scope 63
Table 5.11 Later native and external stage decision medians 64
Table 5.12 Fresh case confusion counts and balanced accuracy 65
Table 5.13 Fresh case decisions from the common evaluator 65
Table 5.14 Early warning coverage on five simulated role call cases 68
Table 5.15 Four new bounded REGISTER controls 70
Table 6.1 Coverage of the research objectives 73
Table B.1 Frozen logistic feature scaling and coefficients 80
Table C.1 Canonical evidence directories 81

List of Abbreviations

ACK	SIP acknowledgement request
ARI	Asterisk REST Interface
CDR	Call detail record
CEP	Complex event processing
CPU	Central processing unit
DDoS	Distributed denial of service
F1	Harmonic mean of precision and recall
FN	False negative
FP	False positive
FPR	False-positive rate
IPC	Inter-process communication
ML	Machine learning
NAT	Network address translation
PBX	Private branch exchange
PCAP	Packet capture
RQ	Research question
RSS	Resident set size
SIP	Session Initiation Protocol
TN	True negative
TP	True positive
UAS	User agent server
VoIP	Voice over Internet Protocol
WLAN	Wireless local area network

Chapter 1 Introduction

1.1 Background

Voice over IP (VoIP) has become a core communication technology across enterprise, carrier, and service-provider environments because it offers flexibility, scalability, and cost efficiency. Session Initiation Protocol (SIP) is widely used at the signalling layer to establish, modify, and terminate communication sessions [1]. In operational PBX environments, SIP exchanges produce behavioural evidence through messages such as REGISTER, OPTIONS, INVITE, ACK, and BYE, together with response codes, transaction identifiers, dialog state, and timing information. Asterisk also exposes programmatic interfaces and reporting facilities that can support monitoring, event collection, and call-level analysis [2]-[4].

The same openness that makes SIP flexible also creates an attack surface. Toll fraud is particularly important because an attacker who gains access to a SIP account or calling route can generate unauthorized calls to international, premium-rate, or other costly destinations. Such abuse may not begin with fraudulent calling immediately. It can progress through endpoint discovery, repeated registration or authentication attempts, credential compromise, and finally abnormal outbound call activity. Prior work has demonstrated the value of real-time fraud monitoring [5], stateful SIP inspection [6], behavioural call-record analysis [7], and machine-learning-based SIP attack detection [8], but these approaches are commonly evaluated as separate problem classes rather than as one toll-fraud progression.

This research investigates whether SIP signalling evidence can be organized into an interpretable progression model that identifies suspicious evolution before a burst of calls. The prototype was refined using controlled experiments, causal machine-learning features and independent SIP and CDR checks. The resulting alerts represent observable suspicion; experimenter-assigned authorization cannot be inferred reliably from an identical SIP sequence.

1.1.1 From SIP observations to research claims

The starting point of the study is a distinction between a protocol observation and the explanation attached to it. A captured request establishes that a message was visible at a

particular observation point. A matched response establishes something about the handling of that transaction. An authentication log can corroborate a credential rejection, while an answered call record can corroborate completed laboratory activity. None of these records, by itself, establishes the identity, authority or financial intention of the person controlling the endpoint. Early detection is therefore examined as the timely recognition of an observable pattern that warrants review. This definition permits useful security monitoring without presenting every unusual registration or call as verified fraud.

That distinction also explains why several evidence layers are retained. Packet traces provide a relatively detailed sequence, including requests that never become completed calls. PBX authentication logs provide an implementation-specific account of credential processing. CDRs summarize call outcomes after activity has occurred. Their agreement strengthens a claim that a declared laboratory procedure was executed, but their different purposes prevent one layer from simply replacing the others. For example, a completed CDR cannot retrospectively become an input to a warning issued before the first call. Conversely, the presence of an INVITE does not establish that the PBX answered the call or that any chargeable route was used.

The research consequently separates three questions. The first concerns representation: can the detector reconstruct a coherent sequence from probing through failed authentication, registration recovery and subsequent calling? The second concerns discrimination: does the available evidence distinguish the assigned benign and simulated-abuse roles? The third concerns implementation: can the resulting decisions be delivered through native and external PBX paths with observable resource and timing behaviour? These questions are related, yet success on one does not imply success on the others. A correctly reconstructed sequence may remain ambiguous, and a fast implementation may deliver an uninformative score.

This separation gives negative findings a clear role. When matched opposite-role cases receive similar scores, the result identifies an information boundary rather than merely an inconvenient classification error. When a simpler failure threshold warns sooner, progression must be justified through additional interpretation or coverage rather than an unsupported speed claim. The thesis therefore evaluates the architecture through its explicit decisions and denominators. Its practical value is considered alongside the cases in which

review remains necessary and the evidence required before a stronger operational claim could be made.

1.2 Research Problem

The central research problem is how to evaluate a practical, interpretable SIP progression detector when protocol evidence alone may not distinguish authorized recovery from simulated unauthorized use. Existing real-time and multi-stage systems provide important foundations [5], [15], [16]. This study examines the reliability and timing of a bounded PBX prototype, the additional information supplied by independent permissions, and the tradeoffs between false alerts and warnings before outbound calling.

An early warning system must accumulate meaningful evidence while limiting unnecessary alerts. The experiments expose two difficulties: short count windows miss slow patterns, and benign credential recovery can resemble simulated unauthorized use. The refinement therefore tests protocol semantics, longer histories and review priority while preserving these ambiguities in the evaluation.

1.2.1 Threat model and authorization boundary

The controlled threat model assumes that an observer can inspect the laboratory SIP exchanges and can access specified PBX evidence. The simulated progression may include repeated wrong-password attempts, a later successful registration and isolated outbound call attempts. It does not assume that every real attacker follows this sequence. An actor already holding valid credentials could begin with successful registration or calling, while reconnaissance could originate elsewhere and remain outside the observer's history. The evaluated progression is therefore a bounded path through a broader attack space. A missing precursor must not be interpreted as evidence that an account is safe.

Authorization is a separate property from successful authentication. In the laboratory, both benign recovery and a simulated unauthorized role can use a credential that the PBX accepts. The PBX response establishes acceptance under the configured authentication mechanism; it does not establish the legitimacy of the operator. This distinction matters especially after a sequence of failures. The sequence may indicate password guessing followed by access, but it may also indicate a user correcting a stored password. The detector can associate the events and raise suspicion. An authorization judgment requires additional evidence about the account holder, administrative permissions or intended use.

Destination permission introduces another useful distinction. A destination can violate a declared account policy even when the protocol exchange is valid. The permission layer can then produce an actionable review based on the mismatch without claiming to infer the operator's intent. The reverse does not follow: a destination inside an allowlist does not prove legitimate use. An attacker may operate within permitted destinations, and an authorized user may deviate from a narrow laboratory policy. The context experiment deliberately preserves these possibilities by applying the same policy to matched roles. It tests what the policy adds to the observable evidence, including the cases in which it adds nothing.

The resulting scope is defensive and observational. Calling activity is redirected to an isolated user agent rather than a provider or billed service, so the experiment tests signalling progression and policy dispositions without reproducing financial harm. This design supports controlled comparisons and independent completion checks. It also removes important production conditions, including genuine tariffs, customer histories, independently administered recovery records and diverse operational behaviour. The conclusions therefore concern the specified prototype and constructed cases. They do not establish an ability to identify criminal intent, estimate avoided losses or autonomously prevent toll fraud in an enterprise deployment.

1.3 Research Gap

Prior work already demonstrates multi-stage SIP attack monitoring and real-time toll-fraud detection [15], [16]. This study addresses a narrower evaluation gap: how an interpretable PBX progression prototype behaves when benign recovery and simulated abuse share observable SIP patterns, and whether independently declared permissions alter false alerts and pre-call warning coverage. The contribution is auditable integration and bounded evaluation of protocol state, temporally available features, permission context and deployment paths.

1.4 Research Aim

The main aim of this research is to design, build, and evaluate an adaptive multi-stage behavioural progression architecture for early detection of SIP toll fraud in practical VoIP environments.

The term adaptive in the approved title describes the design ambition. The evaluated runtime uses frozen rules and coefficients. Its context layer conditions review on predeclared permissions; autonomous baseline learning and online adaptation were not implemented or evaluated.

1.5 Research Objectives

1. Identify and formalize SIP-level and entity-level behavioural indicators that reveal progression from reconnaissance to authentication abuse, compromise, and fraudulent outbound calling.
2. Develop a stage-aware progression engine that reconstructs SIP behaviour and tracks evolving fraud risk for monitored entities such as IP addresses, extensions, trunks, or destination groups.
3. Implement the proposed detection approach in a controlled Asterisk-based environment and examine practical integration paths for an external detector and an in-process PBX realization.
4. Evaluate whether lightweight machine-learning refinement and CDR-assisted behavioural context improve discrimination between benign anomalies and true fraud progression.
5. Assess technical and operational effectiveness using detection accuracy, false-alert behaviour, time-to-detect, runtime overhead, and mitigation responsiveness under realistic benign and attack scenarios.

Table 1.1 Research objectives and evaluation focus

Objective	Operational focus	Main evaluation indicators
O1 - Behavioural indicators	Identify SIP- and entity-level indicators that distinguish benign activity from early fraud progression.	Feature relevance, separability, response-code/timing patterns
O2 - Progression engine	Track evolving risk and stage transitions per monitored entity.	Correct stage assignment, early escalation, interpretability
O3 - Practical implementation	Implement and compare external and in-process realization paths.	Latency, integration feasibility, maintainability
O4 - ML refinement	Assess whether lightweight ML and CDR context improve rule-based decisions.	Precision, recall, F1-score, false-alert reduction
O5 - Evaluation	Assess technical and operational suitability under benign and attack scenarios.	Time-to-detect, robustness, CPU/memory/processing overhead

1.6 Research Questions and Hypotheses

Primary research question: How can an adaptive multi-stage behavioural progression architecture, driven by SIP dialog semantics and behavioural feature analysis, detect SIP toll fraud early in operational VoIP environments while remaining practical for real-world deployment?

RQ1. Which SIP signalling patterns and behavioural indicators are most reliable for distinguishing normal activity from early-stage toll fraud progression?

RQ2. How effectively does a stage-aware progression model detect suspicious entities earlier than threshold-based or single-event detection approaches?

RQ3. To what extent does lightweight machine-learning refinement improve precision, false-alert control, and overall risk scoring when combined with rule-based progression tracking?

RQ4. How do the two deployment options, namely in-process PBX integration and external service integration, compare in terms of detection latency, runtime overhead, maintainability, and operational practicality?

The corresponding hypotheses retained from the approved proposal are:

H1. The proposed multi-stage framework will detect SIP toll fraud earlier than basic baseline methods.

H2. Adding lightweight machine-learning refinement will reduce false alerts and improve overall detection quality compared with a rule-only stage engine.

H3. The in-process deployment option will provide lower detection latency, while the external deployment option will be easier to maintain and still provide acceptable overhead.

The hypotheses are evaluated on matched scenarios using coverage and explicitly defined timing endpoints. H2 is assessed using frozen causal scores on fresh whole scenarios. H3 is examined through shared-authentication alert availability, process resources and call setup; full-stage parity and maintainability are not treated as measured merely because two deployment paths exist.

1.7 Scope of the Study

The study is limited to defensive observation in an authorized laboratory. Later experiments use two Raspberry Pis, accounts 1001 and 1002, and a temporary route to a SIPp user agent server. No stolen credentials, provider calls, billed destinations or customer traffic are used. SIPp labels describe assigned experimental roles. CDRs corroborate completed lab calls; they do not establish fraud intent or a production calling baseline. Automatic blocking, throttling and account locking remain proposed capabilities rather than implemented mitigation.

1.7.1 Interpretation of an early warning

An early warning is useful only relative to a clearly stated decision opportunity. In this study, a review issued before the first linked generator INVITE offers an opportunity to investigate before calling begins. A decision issued at that INVITE identifies an attempted policy violation but offers no positive pre-call lead. A later CALL_BURST event describes accumulating call activity. These outcomes may all be operationally relevant, but they represent different intervention points. Treating them as equivalent detections would hide whether the method actually provided time before the first attempt.

The warning endpoint must also be distinguished from a verified harmful outcome. A suspicion stage can be correctly triggered by the laboratory rule even when the assigned role is benign. Likewise, a case assigned a simulated-abuse role may remain unflagged because its observable behaviour matches an allowed recovery. The evaluation therefore retains both the procedural meaning of the stage and its classification against the assigned role. This avoids changing the meaning of a positive prediction after its result is known. It also allows a reviewer to see whether an apparent gain arises from a new source of information, a different alert disposition or a changed threshold.

A warning does not automatically establish that an effective mitigation was available. Blocking a source could disrupt multiple legitimate accounts, and locking an account could prevent a genuine user from recovering access. The present prototype records and prioritizes review rather than executing those actions. Its warning times describe potential opportunities for a future operator or mitigation component. They do not measure the time required to authenticate an administrator, decide on a response, apply a control or restore legitimate service. Those later steps require their own experiments and acceptance criteria.

The same discipline applies to latency. Event-time replay asks when sufficient evidence exists in the captured sequence. Live availability asks when a particular implementation exposes its decision to an observer. A policy can qualify at an early packet timestamp while its notification arrives later because of capture, decoding or delivery. Conversely, a short service-computation time does not establish that the complete path is timely. The thesis keeps these clocks separate so that a rule's information requirement is not confused with the performance of the software used to observe or deliver it.

1.8 Significance and Contributions

The study contributes an interpretable progression artefact and an evaluation that distinguishes observable protocol behaviour from assigned authorization roles. Confirmed authentication semantics, linked recovery and calling, frozen event-time scoring and permission-conditioned review are examined through separate evidence families. The results include negative findings: the frozen lightweight model does not separate matched roles, a simple failure threshold warns earlier in the comparable call cases, and contextual false-alert reduction reduces pre-call warning coverage. These findings provide practical evidence about what this controlled prototype can support and what requires independent policy or operational validation.

1.8.1 Contribution and evidence expectations

The contribution is best understood as a connection between an explicit artefact and a transparent evaluation. The artefact makes its stage conditions inspectable: it records what counts as a confirmed authentication failure, which entity history is consulted and which subsequent call can be linked. The evaluation makes its boundaries inspectable: it distinguishes development traces from fresh cases, scenario decisions from packet counts and completed laboratory calls from actual toll fraud. Together, these properties allow the reported behaviour to be examined without relying on a single aggregate accuracy figure.

Interpretability here concerns traceable decisions rather than a claim that the underlying problem is simple. A reviewer should be able to identify the events that satisfied a rule, the information available when a score was calculated and the permission that changed a disposition. Such a record is particularly important when the model is wrong or inconclusive. An unexplained numerical score could conceal whether a result was driven by future call information, a repeated packet or a role label. An explicit progression and

evidence record makes those alternatives easier to examine, while still requiring independent validation of the implementation.

The contextual experiment contributes a decision tradeoff: independently declared permissions reduce actionable false alerts but also reduce pre-call warning coverage for some simulated-role cases. Reporting both outcomes identifies the administrative evidence and operating choices that a future study must test. This gives the prototype a reproducible research purpose without using terminology, implementation speed or correlated packet counts as substitutes for discrimination.

1.9 Thesis Organization

Chapters 2 and 3 review prior work and define the laboratory methods. Chapter 4 describes implementation, and Chapter 5 reports measured results. Chapter 6 evaluates the hypotheses and remaining limitations.

Chapter 2 Literature Review

2.1 Introduction

This chapter reviews research streams directly relevant to early detection of SIP toll fraud. The review is organized around SIP/VoIP security foundations, real-time fraud monitoring, stateful and protocol-aware anomaly detection, CDR-based behavioural analytics, machine-learning-based SIP attack detection, and the specific gap addressed by the proposed progression architecture.

2.2 SIP and VoIP Security Foundations

SIP is an application-layer signalling protocol used to create and manage multimedia sessions [1]. Because the protocol is transaction- and dialog-oriented, security monitoring can use relationships among requests, responses, dialog identifiers, authentication challenges, and timing rather than relying only on message counts. Protocol-state-machine research has shown the value of modelling interacting SIP/VoIP states [13], while survey work documents the broad exposure of SIP-based VoIP systems to signalling attacks and flooding behaviour [14]. These characteristics support stateful detection, but they also mean that exposed SIP services can be scanned, enumerated, subjected to repeated authentication attempts, and misused for fraudulent calls once valid access is obtained.

2.2.1 Transaction semantics and evidence quality

SIP semantics constrain the meaning of security features. RFC 3261 defines transactions and the exchanges through which registration and session establishment are handled [1]. For this thesis, the important consequence is that a response code must be interpreted in relation to the request and exchange that produced it. A normal authentication challenge and an authenticated credential rejection can share superficially similar response information. Counting all challenges as failed passwords would therefore make ordinary protocol operation resemble an attack. The detector's feature extraction must resolve that ambiguity before its thresholds or learned scores are evaluated.

Matching an event to its transaction also reduces accidental inflation. A source may retransmit a request, and a monitor may observe repeated packets for the same exchange. If each visible packet becomes an independent failed-password event or call, the apparent progression can advance without any new action by the endpoint. The laboratory

implementation consequently distinguishes confirmed failures and distinct call identifiers from raw packet volume. This is a methodological requirement as much as a software detail: the unit represented by a feature should correspond to the behaviour that the research claim names.

A response remains evidence about the monitored exchange rather than a complete account history. A successful registration establishes that the server accepted a binding request under its configured conditions. It does not prove that a password was stolen. A failed request may be informative about an attempted account, but it does not identify the human responsible. These distinctions are especially important when entity histories are keyed by source and account. The keys make sequence reconstruction possible; they do not eliminate shared addresses, legitimate device changes or the possibility that one actor uses several sources.

The observation point also determines which relationships are available. A PBX-side capture can reveal exchanges handled by that PBX, while a native security event presents the implementation's interpretation of a subset of those exchanges. The external path additionally depends on capture and decoding. Agreement across these views strengthens a bounded implementation check, but disagreement requires diagnosis rather than choosing whichever record produces a preferred score. Missing packets, differing clocks and event filtering can change what appears to be an ordered progression. The evidence pipeline must preserve enough detail to make such differences visible.

These considerations motivate a protocol-first order of analysis. First establish what the request, response and associated identifiers support. Then aggregate the normalized behaviour over a declared history. Finally apply a stage or review policy. Reversing that order risks allowing a desired attack label to determine how ambiguous packets are interpreted. The method adopted here treats semantic normalization as part of the detector specification, while independent logs and completed-call records check execution. The resulting features remain imperfect observations, but their meaning is more precise than an unqualified count of SIP messages.

A toll-fraud detector therefore benefits from observing several evidence layers. Signalling records reveal early probing and authentication activity, while CDRs and call-routing records provide information about completed calls, duration, destinations, trunk use, and

changes from normal calling behaviour. The research problem is not simply to classify an individual packet as malicious, but to determine whether multiple weak signals form a meaningful progression.

2.3 SIP Toll Fraud and Behavioural Progression

Real-world SIP abuse can involve reconnaissance, account discovery, authentication attacks, credential compromise, and subsequent fraudulent calling. Aziz [15] emphasizes that toll-fraud attacks should be interrupted as early as possible, before an attacker learns enough information or generates high-cost traffic. A distributed SIP attack-monitoring infrastructure has also shown the value of correlating observations across security sensors [16]. These works support the thesis premise that defence should reason across stages rather than wait for a final billing anomaly.

2.3.1 Position relative to multistage toll fraud research

Multistage SIP toll-fraud analysis is an established research direction. Aziz's dissertation describes a detection and mitigation system grounded in real attack patterns and evaluates a prototype with Internet field observations [15]. The distributed infrastructure of Aziz et al. likewise places SIP attacks within a staged monitoring problem across observation locations [16]. These works are direct predecessors to the present research. Their existence means that representing reconnaissance, account access and subsequent calling cannot, by itself, establish novelty. A defensible contribution must identify the particular design decisions and evaluation questions added by this study.

The present prototype focuses on a narrow but consequential ambiguity: two actors with different assigned roles can produce effectively the same observable recovery and call profile. This differs from asking whether a sensor can detect an obviously hostile sequence or whether a mitigation component can interrupt an attack in a field deployment. The matched cases ask whether the available input actually contains the information required for an authorization decision. A negative answer constrains how rule stages and learned scores should be named and used. It does not negate the value of earlier multistage monitoring or establish that real attack traffic is universally indistinguishable.

The experimental setting further changes the interpretation of success. Prior field-oriented work can observe diverse unsolicited activity, whereas this thesis uses deliberately constructed laboratory traffic and isolated destinations. Construction makes the event

sequence, declared role and expected call completion easier to control. It also makes the sample less representative of the range of behaviours an exposed PBX might encounter. The study therefore uses its control to examine causal availability of features, implementation parity and review tradeoffs, rather than treating the laboratory as a substitute for the field evidence reported in prior toll-fraud research.

The relationship is consequently complementary. Existing multistage systems establish the relevance of linking SIP behaviour across an attack path. This thesis examines how a lightweight implementation can preserve the distinction between that observable path and an authorization claim, and how independent permissions alter review decisions on fresh controlled cases. The contribution lies in the explicit operational definitions, retained failure cases and bounded comparisons. It should be assessed through those properties and the reported limits, rather than through a claim that previous research lacked real-time or multistage toll-fraud detection altogether.

2.4 Real-Time Fraud Detection

Manunza et al. proposed Kerberos, a real-time fraud detection architecture for IMS-enabled VoIP networks that processes charging and call-evolution events using complex event processing [5]. Its main relevance to this thesis is the demonstration that fraud detection and remediation can occur while communication activity is still in progress rather than only through post-event billing review. Application-aware flow monitoring has likewise been investigated for SIP fraud detection [17]. These approaches support online monitoring, although they do not directly implement the progression model evaluated in this thesis.

2.4.1 Event correlation and the meaning of real time

Kerberos illustrates an important architectural principle: events associated with the setup, evolution and termination of a call can be correlated while activity is still in progress, rather than relying exclusively on a final billing record [5]. Its use of online charging events and complex event processing concerns a different observation layer from the packet-centred progression in this thesis. The relevant lesson is not that one input replaces the other, but that a security decision can be derived from a sequence whose elements become available at different times.

For the present design, an event must carry sufficient identity and timing information to be related to earlier evidence. A failure history tied only to an address could combine different

accounts, while a history tied only to an account could obscure changes in the observed source. A linked progression therefore requires declared association rules. Those rules are part of the hypothesis being tested: changing the key, expiry window or link condition can change both coverage and unnecessary alerts. Event correlation is not a neutral preprocessing step when it determines which behaviours the detector treats as belonging together.

The phrase real time also requires an endpoint. Processing each incoming normalized event demonstrates online execution, but it does not establish that notifications arrive within an operational deadline. The full path may include packet buffering, decoder output, interprocess communication and logging. A fast rule evaluation can coexist with a comparatively delayed externally visible alert. Conversely, a larger evidence-accumulation interval may be necessary to avoid misinterpreting a normal challenge. A complete evaluation must therefore distinguish the waiting time required by the policy from the additional delay introduced by its implementation.

This distinction informs the comparison with a final CDR workflow. A packet-stage review can precede call completion, while a CDR can later confirm that a call was answered. The earlier decision has a timing advantage for that specific opportunity, but less outcome information. The later record has more complete call evidence, but cannot support a warning that predates the call. Neither timing position alone determines detection quality. The appropriate question is whether the available information justifies the decision required at that point, with the false-alert consequences and missed cases retained.

The thesis adopts this event-based perspective without claiming a complete carrier-grade charging architecture. The common replay evaluator isolates when each method qualifies on the same captured sequence. The deployment pilots then expose selected delivery and processing observations. Keeping those experiments distinct makes the design easier to interpret: a replay result concerns policy behaviour, while a live measurement concerns a specific implementation path under the pilot conditions. Their combination supports implementation understanding without silently converting a descriptive laboratory observation into a production guarantee.

2.5 Stateful and Protocol-Aware SIP Detection

Seo et al. introduced SIPAD, which uses a stateful rule tree for SIP anomaly detection [6]. Golait and Hubballi model anomalous VoIP behaviour as a discrete event system [9]. These studies show why protocol state and sequence matter alongside counts. The present implementation applies this reasoning to a bounded toll-fraud progression experiment and evaluates evidence accumulation, ambiguity and warning time. It does not claim to originate stateful SIP detection.

2.5.1 Stateful inspection and progression representation

Stateful inspection provides a foundation for connecting otherwise isolated observations. SIPAD uses a stateful rule tree for SIP anomaly detection, while discrete-event and interacting-protocol-state research models relationships among protocol states [6], [9], [13]. These approaches demonstrate that valid interpretation can require sequence and context rather than a message considered alone. The present thesis draws on that principle, but organizes its higher-level stages around the investigation of a suspected toll-fraud progression. It does not reproduce the full state representation or scope of every earlier system.

A protocol state and a security stage answer different questions. The protocol state describes where an exchange stands according to the communication procedure. A security stage summarizes the review significance assigned to observed behaviour. Successful authentication may be an ordinary protocol outcome while also completing a suspicious sequence after repeated confirmed failures. The architecture should retain both descriptions. Calling the protocol outcome itself compromise would erase the benign recovery explanation; ignoring its preceding history would erase potentially useful suspicion. The suspected-stage terminology preserves this distinction.

Progression also need not imply a rigid sequence through every possible stage. A successful actor may have no visible reconnaissance or failed authentication in the monitored history. A policy-violating destination can become observable at the call attempt without a prior recovery stage. The permission extension addresses that specific case by evaluating destination evidence when it becomes available. This is a bounded addition to the progression model, not proof that every attack path has been covered. The design

remains explicit about which stages depend on a prior history and which checks can operate independently.

Temporal expiry is equally important. A long history can connect slow behaviour that a short window misses, but can also connect events that a reviewer would consider unrelated. A short history limits retained state and stale associations, but can discard relevant low-rate activity. The laboratory thresholds make these choices inspectable. Their value is not that the particular seconds or counts are universally correct; it is that the resulting tradeoffs can be evaluated on declared cases. A production implementation would need additional workload evidence before those thresholds could be treated as appropriate operational settings.

The comparison with stateful literature therefore supports a design discipline rather than a performance ranking. The detector should expose the state required for each decision, preserve distinct transactions and specify expiry and association conditions. Evaluation should then ask which cases benefit from that state and which remain ambiguous. More elaborate state can improve explanation while leaving a classification unchanged. That outcome is still informative, provided the thesis does not equate additional stage detail with demonstrated earlier detection or superior fraud discrimination.

2.6 CDR and Telecom Behavioural Analytics

CDR-based research provides a complementary view of fraud. Chiappetta et al. analyze anomalies in the social behaviour of VoIP users using call records [7], showing that user-level behavioural context can reveal suspicious patterns that may not be obvious from one protocol event. User-profiling approaches have also been applied to VoIP scam and fraud detection [18]. More recent telecom fraud work uses graph-learning and dynamic graph models to exploit relationships among users, destinations, and time [10], [11]. These approaches are powerful for behavioural profiling but are often oriented around completed call activity. In this thesis, CDR evidence is therefore treated as contextual reinforcement for the faster SIP-signalling detector rather than as the only source of early warning.

2.6.1 What call records add to signalling evidence

CDR-based work examines a different level of behaviour from an individual registration exchange. Chiappetta et al. construct representations of users and their communication relationships from operator call records, while Kapourniotis et al. investigate user profiling

for VoIP scam and fraud detection [7], [18]. These studies motivate attention to calling context, but they do not justify assuming that a small isolated laboratory CDR set constitutes a learned normal-user profile. Such a profile requires a history whose coverage, labels and relationship to the monitored entity are understood.

Within the present experiments, the strongest justified role of a CDR is corroboration. If the declared scenario should produce a specified number of answered isolated calls, added records can check whether the PBX recorded that outcome. This is more informative than counting INVITEs alone. It remains a different claim from knowing that the calls were unauthorized, costly or abnormal for a genuine subscriber. The destination is a controlled laboratory route and the call duration is scripted. Those properties provide repeatability while limiting the behavioural meaning of the record.

The distinction between aggregate completion and exact identity linkage is also material. An increase in answered CDRs can corroborate a batch under controlled conditions, yet a general-purpose detector must associate each relevant record with the correct signalling entity and time interval. Multiple legs, concurrent activity or implementation-specific identifiers can make that association more complex. The thesis accordingly does not claim a universal exact mapping from SIP Call-ID to PBX CDR identifiers. Broader linkage would require additional validation before CDR-derived histories could safely influence account-level review.

A future historical feature also has an availability time. A duration is unknown before a call ends, and a pattern defined over subsequent destinations cannot be used at the first successful registration. Including such values in an early classifier would answer a retrospective question while appearing to evaluate a pre-call decision. The frozen score therefore excludes these outcomes. This restriction may reduce predictive information, but it preserves the decision point that the research question requires. A weaker result from available information is more interpretable than a strong result obtained from future evidence.

Signalling and CDRs are thus complementary within a time-aware evidence model. Signalling can support early suspicion and transaction reconstruction. Completed records can verify outcomes and, where a suitable independently validated history exists, contribute later behavioural context. The present work implements the first roles and

checks isolated completion. It leaves production baseline learning and robust concurrent linkage as future work. This boundary prevents the phrase CDR-assisted architecture from being read as evidence that a representative behavioural prior was trained or that completed-call anomalies were established in the current laboratory.

2.6.2 Graph models and the scale of contextual evidence

Graph-based telecom research expands context from an isolated subscriber to relationships among entities. BTG investigates graph learning from telecommunications CDR metadata, and the dynamic collaborative-fraud work of Ren et al. models relationships that vary over time [10], [11]. These studies are relevant because a suspicious participant may be more identifiable through shared recipients or coordinated behaviour than through one local event sequence. Their input conditions, however, differ substantially from two laboratory accounts producing a small number of scripted isolated calls.

The lesson for this thesis is an information requirement. A graph method needs meaningful nodes, relationships and observation periods. Creating a graph from a handful of declared scenarios would not automatically supply the social or collaborative structure studied in telecom datasets. It could instead encode the generator design, account assignment or script schedule. Before using relational features, a deployment would need to establish what an edge represents, when it becomes available and whether it reflects independent user behaviour rather than an artefact of collection. Model sophistication cannot compensate for an unsuitable representation.

Graph context also changes the unit of evaluation. If several cases share accounts, destinations or a common collection period, their features may not be independent. An evaluation that separates individual records while retaining closely related entities in training and testing can answer a different question from generalization to a new account or network. The present experiments avoid claiming such generalization. Their same-case comparisons test the declared rule and permission decisions on controlled episodes; they do not estimate how a relational model would perform on unseen subscriber communities.

The independent permission layer is therefore deliberately narrower than graph-based behavioural learning. It asks whether an administrator's declared source, account, destination and recovery permission changes an actionable review. These fields have an explicit policy meaning and a controlled availability time. They do not represent learned

relationships, evolving communities or a production normality model. Treating them as a separate context source keeps the experiment interpretable. A future study could investigate richer relational history, but would need new data, identity linkage, split design and evaluation targets rather than simply relabelling the present permission matrix.

2.7 Machine Learning for SIP Attack Detection

Machine-learning research has shown that temporal and protocol-specific features can improve the detection of SIP flooding and related attacks. Younes proposes a hybrid deep-learning model for SIP-based DDoS detection [8], while Dassouki et al. use temporal and structural fingerprints to protect cloud-based SIP environments [12]. Survey evidence also shows that SIP DoS/DDoS defence depends strongly on protocol-aware traffic characteristics [14]. These studies motivate the use of timing, rate, diversity, and response-code features. The present work intentionally targets a lightweight model rather than a deep architecture so that risk refinement remains interpretable and deployable near a PBX.

2.7.1 Matching the learning task to the fraud question

SIP flooding and toll fraud share a signalling environment while posing different inference problems. Younes studies a deep-learning approach to SIP flooding, and Dassouki et al. use temporal and structural fingerprints with a mitigation mechanism for cloud-based flooding [8], [12]. Their relevance is that protocol-specific timing and structure can contain useful attack information. It would be inappropriate to transfer their effectiveness directly to an authorization decision after a valid registration. Flooding evidence can concern service availability, whereas the matched recovery cases here can remain valid protocol exchanges under both assigned roles.

This difference determines what a benchmark can support. A classifier that distinguishes flood-labelled records from ordinary traffic has demonstrated performance for that dataset and label definition. It has not necessarily identified stolen credentials, a forbidden account operator or costly completed calls. Even when a benchmark uses SIP fields, the target variable remains essential. The present thesis therefore keeps any separate flooding task outside the end-to-end toll-fraud result. A high score on a related protocol task cannot repair a lack of intent information in the controlled progression profiles.

A lightweight model was selected for review priority because its inputs and inference can be inspected alongside the rules. The choice does not establish that a small model is more

accurate than a deep model, nor that every PBX requires the same computational compromise. Its methodological advantage in this experiment is visibility: four defined pre-decision features lead to a frozen score and declared categories. When opposite-role cases receive similar categories, the relationship between the available evidence and the negative result remains understandable without attributing the outcome solely to model complexity.

A more expressive model could fit additional distinctions in a constructed dataset, but that would not demonstrate that the distinctions represent authorization. Differences caused by script timing, capture order or endpoint configuration may separate declared cases without describing the security property of interest. Matched profiles make this problem visible by reducing intended observable differences between roles. They test whether the scoring information supports the role distinction under those conditions. The study does not conclude that all machine learning is ineffective; it concludes that the frozen feature set and evaluation did not demonstrate the proposed refinement benefit.

The appropriate comparison is therefore between defined decision systems on compatible evidence. Rule-only progression, learned review priority and permission-conditioned disposition should retain their separate purposes. A model score can prioritize an existing alert without removing it. A permission can change actionable review because it introduces an independent policy fact. Those mechanisms should not be combined into a single improvement claim unless their individual effects and common evaluation endpoint are shown. The final experiment preserves this distinction by attributing its contextual changes to permissions rather than to the unsuccessful frozen ML separator.

2.7.2 Learning validity and deployment interpretation

Learning validity depends on when information is available and how evaluation examples relate to development. A feature derived from the complete scenario may summarize later behaviour accurately while being unavailable at registration success. A model trained or tuned after the evaluation cases have been inspected may describe those cases without providing a fresh test. The thesis addresses these concerns by freezing the selected features and model before the new matched episodes, while retaining inspected historical traces as development or compatibility evidence. The terminology of fresh evaluation refers to that procedural separation, not to representativeness of a production population.

Whole-scenario separation is important because events inside an episode are strongly related. Multiple packets may express one transaction, and several calls may follow one recovery procedure. Randomly treating those packets as independent examples can make the evaluation appear larger without adding independent behavioural variation. The study consequently reports case-level counts where the decision concerns a scenario. This does not make twelve constructed cases a large sample, but it makes their denominator correspond to the claim. Repeated observations can still support execution checks and descriptive timing while remaining clustered within a case.

A score also needs a stated interpretation. The frozen logistic output is used to assign review categories, not presented as a calibrated probability that a real caller is committing fraud. Calibration would require evidence that the score corresponds to observed outcome frequencies in a relevant population. The constructed, balanced and deliberately matched cases do not provide that evidence. The category thresholds are experimental settings whose effect is observable in the reported cases. A deployment would need to consider the operational costs of missed abuse, unnecessary review and disruptive intervention before adopting any threshold.

The negative result is consequently precise. The model was integrated, its score could be delivered, and matched opposite-role profiles received the same category. Those observations establish reproducible execution and lack of demonstrated discrimination under the tested conditions. They do not establish that increasing the model size would solve the missing-information problem, nor do they establish that all contextual inputs would fail. The permission experiment addresses the latter possibility separately, exposing both a reduced false-alert count and an early-warning tradeoff rather than claiming that a new context source removes ambiguity.

2.8 Comparison of Selected Related Work

Table 2.1 Comparison of selected related work

Study	Primary data/method	Strength relevant to this thesis	Remaining gap
Manunza et al. [5]	Charging/service events with CEP	Real-time fraud monitoring and remediation	Limited SIP dialog progression
Seo et al. [6]	Stateful SIP rule tree	Protocol-aware stateful detection	Not specifically a toll-fraud lifecycle

Study	Primary data/method	Strength relevant to this thesis	Remaining gap
Chiappetta et al. [7]	CDR behavioural profiling	Normal-behaviour context	Primarily post-call / CDR oriented
Golait and Hubballi [9]	Discrete-event VoIP modelling	State and sequence representation	General VoIP anomaly focus
Younes [8]	ML for SIP flooding	Protocol/timing features and intelligent classification	Flooding focus rather than toll-fraud progression
Hu et al. [10]; Ren et al. [11]	Graph-based telecom fraud analytics	Entity relationships and temporal behaviour	Requires richer call-history data; not PBX signalling-time detection
Aziz [15]	Real-time SIP toll-fraud mitigation	Direct relevance to multi-stage toll fraud	Established multi-stage toll-fraud detection; the present study tests a narrower ambiguity and permission-review evaluation

2.9 Research Gap and Positioning

The study evaluates an interpretable progression architecture using controlled SIP signalling, completed-call evidence, a lightweight refinement layer and bounded deployment pilots. The evaluation also tests the limit of signalling-only intent classification. Improved staging and implementation feasibility are assessed separately from a claim of verified toll fraud.

2.9.1 Critical synthesis and design requirements

The reviewed work supports several complementary design requirements. Protocol-state research motivates preserving relationships among exchanges rather than reducing every message to an isolated count [6], [9], [13]. Real-time fraud monitoring motivates decisions before a final billing review [5]. User and graph profiling motivate attention to evidence beyond one packet sequence [7], [10], [11], [18]. Multistage toll-fraud research establishes the relevance of linking reconnaissance, access and calling [15], [16]. The present design combines selected elements for a controlled question; it does not claim to reproduce the scope or strongest empirical results of all these approaches.

The first requirement is semantic traceability. Each feature should have an operational definition that allows a reviewer to connect it to observed evidence. The second is temporal validity. A decision should use only information already available at its declared event. The third is separation of evidence and policy. A protocol sequence can remain visible even when a permission changes whether it warrants actionable review. The fourth is evaluation consistency. Methods compared on the same cases should use the same role definitions and clearly distinguish changes in the event stream from changes in the decision rule.

These requirements explain why the architecture retains multiple outputs. Raw progression stages document what the protocol rules observed. Review priority documents the frozen model's interpretation of eligible features. Context disposition documents an independent permission decision. Completed-call evidence documents execution after the relevant attempt. Keeping these records separate permits a reviewer to identify the source of an improvement or failure. If a positive decision changes because a destination violates an allowlist, that is a policy contribution. If a score merely changes category without altering an alert, it should not be counted as a reduction in false alerts.

The requirements also constrain the contribution claim. A lightweight and interpretable architecture is useful only to the extent that its representation, decisions and implementation are validated. Ease of describing rules does not prove maintainability; low process CPU in a small pilot does not prove acceptable production overhead; stage parity does not prove fraud discrimination. The thesis therefore treats each of these as a distinct proposition with its own evidence. The resulting research gap is an evaluation gap addressed by explicit matched-role and permission experiments, rather than an assertion that the literature lacks staged SIP security architectures.

2.10 Conceptual Framework

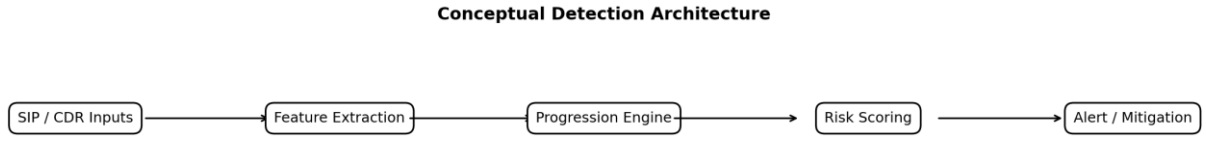


Figure 2.1 Conceptual detection architecture

The conceptual framework links SIP evidence, behavioural state and review decisions. The implemented V6 path now emits suspected compromise after repeated confirmed failures and a valid registration, followed by linked lab call attempts. Completed calls are corroborated using SIP and CDR evidence. The conceptual diagram includes mitigation options; the prototype is observation-only and does not execute call blocking, throttling or account isolation.

2.10.1 Information boundaries in the conceptual framework

The framework can be read as a sequence of information boundaries. The protocol adapter converts captured or native observations into normalized events. The progression engine retains the history needed by its rules. The optional score summarizes eligible history at a declared registration event. The permission layer consults independent administrative context as that context becomes relevant. Later SIP completion and CDR checks corroborate execution. Each boundary should preserve the distinction between what was observed, what was derived and what remains an interpretation. Otherwise a later fact can accidentally appear to justify an earlier decision.

The same boundaries guide failure analysis. If a scenario has no expected alert, the review can ask whether the required event was absent, the association failed, the history expired or the rule deliberately did not qualify. If a permission changes the actionable result, the record should identify the relevant permission rather than describe the change as unexplained adaptation. If the native and external implementations disagree, the comparison should first check which normalized evidence reached each path before attributing the difference to their decision logic. This decomposition makes the architecture testable without implying that every component was independently benchmarked.

Mitigation appears in the conceptual architecture as a possible downstream use of review evidence. In the measured prototype, the boundary ends at observation and reporting. A future control component would have to translate suspicion into an action, verify that the action applied to the intended entity and assess harm to legitimate service. The present laboratory does not measure those steps. Maintaining the conceptual distinction allows the thesis to discuss the relevance of early review while keeping its implemented contribution and measured outcomes accurately bounded.

2.11 Chapter Summary

The literature provides established approaches to stateful SIP analysis, behavioural profiling, multi-stage attack monitoring and real-time toll-fraud detection. The research contribution therefore depends on the transparency and scope of the present evaluation, including protocol confirmation, temporally available features, matched-role ambiguity and independent permission context. The next chapter defines the controlled design-science methodology and the evidence required to assess those questions.

Chapter 3 Research Methodology

The study uses design science and controlled experiments to build and evaluate a SIP progression artefact. Development, retrospective audit and fresh evaluation are reported separately. Evidence is checked independently of detector predictions, and assigned attack roles are distinguished from confirmed protocol behaviour.

3.1 Design science process and evaluation sequence

The research artefact comprises the event interpretation rules, entity histories, stage transitions, review metadata and evidence pipeline. Its development follows a problem driven sequence: identify a failure in an observable behaviour, implement a bounded change, examine its consequences on preserved evidence, and then evaluate a frozen candidate on declared new cases. This sequence matters because a detector can appear accurate when its rules are repeatedly adjusted to the same examples. The thesis therefore distinguishes an iteration that helps construct the artefact from an experiment that can test a subsequent claim. An improvement on the F series is evidence of development progress; it does not by itself estimate performance on previously unseen operating environments.

The experimental sequence also separates three different forms of contribution. Protocol interpretation concerns whether the system represents the observed exchange correctly, for example by distinguishing an initial authentication challenge from a rejected credential submission. Progression reconstruction concerns whether those interpreted events can be linked into an understandable source and account history. Predictive discrimination concerns whether an alert separates the assigned benign and simulated abuse roles. A successful implementation can establish the first two without establishing the third. This distinction allows a negative classification result to inform the research rather than being hidden behind a demonstration that the software runs.

Later experiments add information rather than retroactively redefining earlier observations. The causal logistic evaluation asks what can be learned at successful registration from failure history alone. The independent context experiment then asks whether a separately declared permission record changes actionable review. The deployment pilots ask whether selected decisions can be delivered through native and external paths. None of these questions is answered by combining all captured packets into one pooled accuracy value.

Their different units, timing origins and available information are retained throughout the analysis.

3.2 Laboratory Configuration and Evaluation History

Initial experiments used an Azure-hosted Asterisk environment with labelled Python-generated traffic. Subsequent experiments used a Raspberry Pi PBX and a separate SIPp generator. The earlier loopback benchmarks are retained as historical baselines; their event-level metrics are analysed separately from the later scenario-level SIPp results.

Table 3.1 Later two Pi laboratory

Component	Implementation	Role
PBX Pi	Astrix-lab; Asterisk 20.6.0; 172.16.200.81	SIP responses, security events and CDRs
Generator Pi	SIPp; 172.16.200.68	Controlled registration and isolated calls
Lab accounts	1001 and 1002	Known valid and wrong-password scenarios
Call destination	Temporary 88001 or 88002 route to SIPp UAS on port 5090	No provider or billed destination
Evidence	tcpdump, tshark, auth logs and CDR snapshots	Independent packet and call verification

As shown in Figure 3.1, packets supply event-time evidence while authentication logs and CDRs supply independent checks. CDRs become available after call activity, so they are not inputs to the early REGISTER-success ML score.

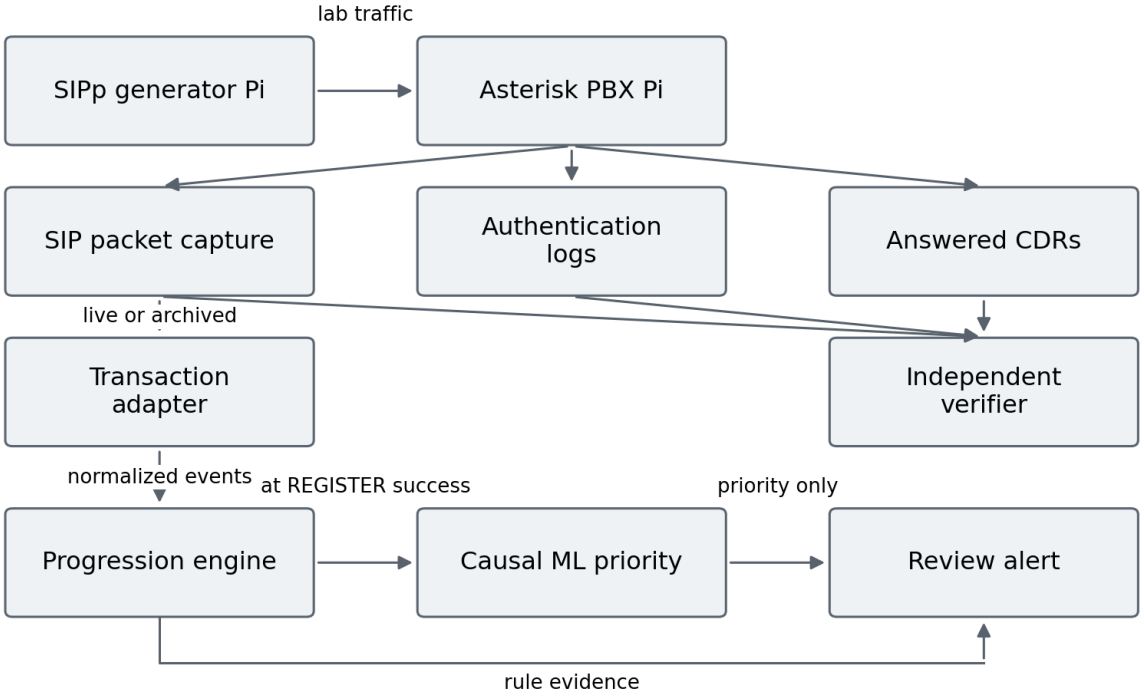


Figure 3.1 Laboratory evidence and early scoring pipeline

3.3 Sampling Units and Evidence Families

A scenario or recovery episode is the evaluation unit. Packets inside one scenario are not independent samples. Opposite assigned roles deliberately share observable traffic profiles to test whether the available signals can distinguish intent. All simulated use remains authorized laboratory activity.

3.3.1 Threat model and observational units

The assumed threat is misuse of SIP access that may be preceded by probing or unsuccessful authentication and followed by outbound calling. The detector observes evidence consistent with this sequence; it does not observe theft of a password or a person's authority to operate an account. In the laboratory, credentials supplied for a simulated role are still used under the researcher's authorization. Consequently, the word simulated identifies the experimental role, while unauthorized identifies the role being emulated. The distinction prevents a controlled credential recovery sequence from becoming circular proof that an actual compromise occurred.

The source address and account are useful observation keys, but neither is a complete identity. A source can represent several users behind a shared address, and an account can be operated by different people. Likewise, a destination in this laboratory identifies a

controlled route, not a billed international or premium rate service. The permission layer therefore interprets these values only against its declared laboratory record. Unknown source or account evidence remains unknown. An account's existence and a successful digest exchange establish that the PBX accepted the supplied credential, without establishing who supplied it or whether that use was legitimate.

For the later scenario-level comparisons, a complete case is the primary classification unit. Repeated requests, authentication responses and call messages within a case jointly create the pattern being evaluated. Counting them as independent classification trials would give larger scenarios more influence and would understate the dependence introduced by shared state. Calls within a deployment case are similarly clustered observations from one configuration and traffic episode. The thesis reports their individual setup values for transparency but interprets the case medians as descriptive summaries. Replaying an existing capture creates another analysis of the same observation; it does not create another independently generated experiment.

Table 3.2 Evidence families and permitted interpretation

Family	Size or identifiers	Purpose
Earlier loopback baseline	11 repeated runs; fixed scenario structure	Repeatability and event metrics
Earlier boundary experiment	12 scenarios; 68 labelled events	Short-window failure modes
Registered F-series	F01 to F12; 6 benign and 6 simulated attack cases	Development comparison of V3, V5 and V6
Archived progression audit	24 D cases and 10 previously inspected H cases	34-run stage-order replay, not fresh ML testing
Causal ML development	10 eligible recovery episodes	Train and freeze the early score
Fresh causal evaluation	B006 to B015; 5 matched role pairs	One-time priority evaluation; 30 completed calls
Auth deployment pilot	T001 to T006; no calls	Shared-stage alert availability
Call setup pilot	6 accepted cases; 18 calls; 1 failed case retained	Shared-authentication process and setup observations
Later full-stage deployment	B030 to B036; 7 cases, 21 calls	Five-stage pilot; 18 primary calls
Fresh independent-context comparison	C001 to C012; 12 cases, 9 calls	Four frozen same-event methods; roles and policy separated

Family	Size or identifiers	Purpose
Fresh REGISTER controls	P101 to P104; 24 unauthenticated requests	Known/unknown identity and target diversity controls

3.4 Independent Ground Truth and Acceptance Gates

A manifest records the case ID, account, assigned role, authentication count, timing and destination before traffic. The verifier checks distinct generator Call-IDs, successful INVITE responses, ACK and BYE evidence, added answered CDRs, expected authentication logs, packet hashes, zero active calls and route removal. CDRs corroborate an aggregate controlled call count; the experiments do not establish a general exact mapping from SIP Call-ID to CDR unique ID.

3.4.1 Evidence acceptance and failure preservation

The independent acceptance procedure is designed to establish that the intended laboratory activity occurred before interpreting its detection result. A declared attack label is insufficient if a wrong password was never rejected, a registration never succeeded or an intended call did not complete. Packet evidence checks the signalling exchange, authentication logs corroborate the configured failure activity, and before and after CDR snapshots corroborate the completed calls. These sources answer related but distinct questions. Agreement strengthens confidence that the workload was generated as declared; it still does not transform an assigned role into observed criminal intent.

For call cases, a generator Call ID identifies the signalling leg examined for INVITE success, ACK and BYE evidence. Added answered CDRs are checked against the controlled account, route and expected call count. Preserving the before snapshot as a prefix of the after snapshot prevents a later extraction from silently replacing the baseline record. This is an aggregate consistency check under controlled traffic. It does not establish a generally reliable one to one mapping between SIP Call ID and Asterisk CDR unique ID when calls overlap, route through multiple legs or generate multiple records.

Acceptance and detector outcomes remain separate. A verified benign case can produce an alert and must count as a false positive under the declared binary outcome. A verified simulated role can produce no alert and must remain a false negative. Conversely, an incomplete capture cannot be converted into a true negative simply because no alert was observed. The retained B024 failure illustrates why collection errors and algorithm errors

need different records. Declaring replacement cases preserves the original failure and gives the replacement a distinct identity, rather than editing the initial evidence until it appears to satisfy the intended gate.

Figure 3.2 shows the stop-on-failure procedure. Failed captures are retained with their reasons. A replacement requires a new declaration and case IDs; it does not convert the original failed run into a pass.

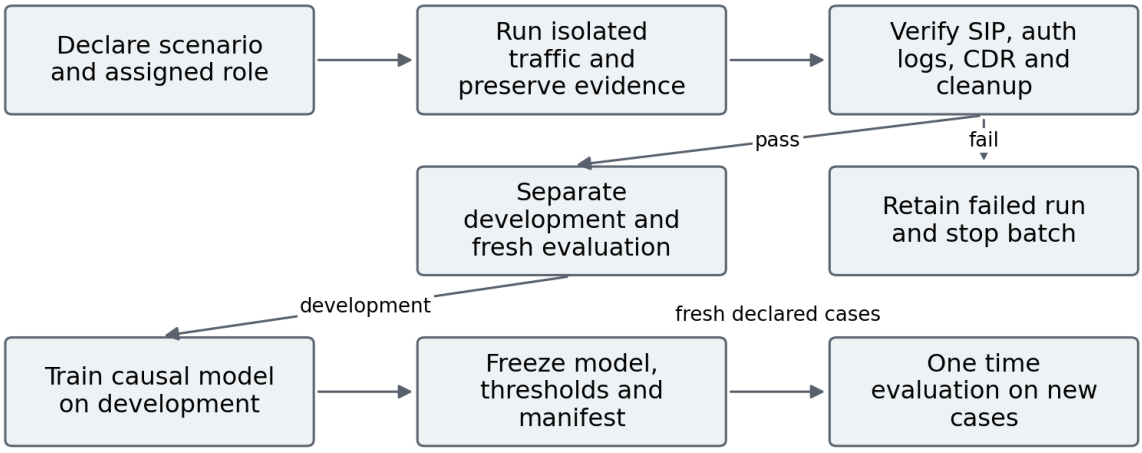


Figure 3.2 Scenario generation validation and frozen evaluation

3.5 Temporally Available Features and Model Separation

Table 3.3 Features available at the scoring event

Feature	Definition
failures_120s	Confirmed failures in the previous 120 seconds
peak_failures_10s	Largest failure count in a 10-second interval within the available history
failure_span_s	Time between first and last available failure
first_failure_to_success_s	Time from first available failure to the current REGISTER success

The causal score is evaluated at the first successful REGISTER after at least five confirmed failures within 120 seconds. Later INVITEs, future call durations, answered CDRs, scenario labels and detector predictions are excluded from its feature vector. An earlier

whole-scenario tree was exploratory because its post-call information was unavailable at this decision point.

A logistic model was trained on ten development episodes. The feature means, scales, coefficients and thresholds were frozen before B006 to B015. Whole episodes and matched profiles were kept together during development validation. No threshold or coefficient was changed after inspection of the new evaluation cases. The ten earlier H cases were already inspected and are not reused as a fresh holdout.

3.5.1 Inference specification and experimental separation

For the frozen model, inference is fully specified by the four feature definitions, their saved means and scales, the coefficient vector and the intercept. Each feature is standardized using its saved development statistics. The linear predictor is the intercept plus the sum of the standardized features multiplied by their coefficients, and the logistic transformation maps that predictor to a score between zero and one. The saved cut points then assign LOWER, REVIEW or HIGHER priority. Applying this calculation does not update the model or learn from a new case. Its purpose is consistent scoring at the same eligible event.

The word causal in this evaluation denotes temporal availability: the score and replay adapter use the current event and its available history rather than later packets or completed-call outcomes. It does not denote identification of a causal treatment effect. This distinction is necessary because the deployment pilots are descriptive and the constructed scenarios do not constitute a randomized operational study. The event-time restriction protects the meaning of an early decision, while the separate timing caveats protect the interpretation of implementation differences. Neither restriction by itself establishes an effect on real fraud losses.

Training reproducibility and frozen-inference reproducibility are related but different. The saved parameters allow a reader to reconstruct the stated scoring calculation, while retraining would additionally require the original development records and fitting configuration. The appendix identifies retained artefacts so those procedures are not conflated. Similarly, replay parity on inspected traces checks whether an adapter preserves the frozen stages; it is not another fresh accuracy estimate. The thesis uses these checks for their stated purposes and reports the new matched cases separately.

A prediction is evaluated against its assigned role only after the method has processed the permitted evidence. This prevents the label from serving as a feature or directly controlling the permission record. It does not make the constructed role an independently observed real-world authorization outcome. The distinction remains visible through the matched benign and simulated-role cases. Those cases are designed to expose a limit: when the method receives the same relevant observations and policy context, different hidden roles may receive the same decision. The result is a test of the information supplied to the method, not proof that the hidden roles became observable.

3.5.2 Feature availability and model freezing

The scoring event defines the information boundary for the causal model. When successful registration occurs, the detector can count prior confirmed failures, examine their local concentration and measure elapsed intervals already completed. It cannot yet know whether a later INVITE will occur, which destination will be attempted, whether a call will be answered or what duration a future CDR will record. Restricting the feature vector at this boundary prevents a retrospective correlate of the outcome from being presented as an early warning signal. The earlier whole scenario tree is therefore exploratory even if its training and test identifiers were separated.

The four causal features express related aspects of the same available history. The 120 second count describes accumulated authentication difficulty. The largest count in a ten second interval describes concentration within that history. The failure span describes the interval between observed failures, while the first failure to success interval includes the time through the successful registration event. These quantities characterize the generated pattern. They contain no direct observation of permission, credential ownership, account operator or financial harm. Matched opposite role profiles deliberately test the consequences of that information constraint.

Freezing records the model together with the interpretation needed to apply it: feature order, means, scaling factors, coefficients, intercept and priority cut points. Without these items, an apparently identical model name could produce a different score. Separating development episodes from later B cases also prevents later labels from determining the chosen threshold. The resulting evaluation concerns the frozen candidate as specified. It does not claim that the ten development episodes represent normal enterprise operation,

and it does not treat the inspected H cases as a fresh test simply because another model could be applied to them.

3.6 Distinct Timing Measures

Table 3.4 Timing endpoints used in the evaluation

Measure	Start	End	Interpretation
Archived stage delay	First captured request	Timestamp of qualifying stage event	Policy evidence accumulation
Pre-call review lead	Review event	First linked generator INVITE	Available suspicion before calling
Live alert availability	Captured successful authenticated REGISTER request	Observed native log or external reply	Delivery path included
Service handling	Service receives event	Service decision timestamp	Capture and decoder excluded
Call setup	First generator INVITE	First PBX INVITE 200 on same Call-ID	INVITE auth exchange included

These endpoints answer different questions and are not pooled. The proposal defines early detection using a high-risk alert; a pre-call REVIEW is reported as a review lead, not silently substituted for a high-risk detection endpoint. Earlier first alerts can also arise from an incorrect interpretation of normal authentication challenges.

3.6.1 Timing interpretation and observation boundaries

A stage delay measures when sufficient qualifying evidence accumulates under a rule. A delivery delay measures when an implementation's output becomes observable. These differ even for the same event. A one second rejection grace deliberately delays confirmation so that a successful retry can cancel a pending failure, whereas buffering, packet decoding, logger delivery and process communication add implementation delay. Removing the grace from a reported authentication delay would change the detector's semantics. Ignoring delivery components would instead change the measured deployment endpoint. Both choices would obscure what the experiment actually observed.

The pre call endpoint is also explicit. A positive lead is the interval from an eligible alert to the first generator INVITE in a simulated role call case. An alert at that INVITE has zero lead and can support review of an attempt, but it has not warned before the attempt. A case without any alert is retained as missed, rather than dropped from a median that describes

only successful warnings. The positive lead median is consequently interpreted alongside coverage. A method can have a favourable median among two warned cases while warning in fewer cases overall.

Causal replay uses the timestamps of the stored observation stream and tests what decision follows from each available prefix. It does not measure how quickly a continuously running service would receive, decode and process those packets. Live deployment results therefore remain separate from the context replay comparison. Similarly, the setup interval ends at the first PBX INVITE 200 for the matched Call ID; it is not a measurement of human conversation quality, media transport delay or the detector's own computation time. Explicit endpoints prevent these different practical questions from acquiring the same time to detect label.

3.7 Classification and Operational Evaluation

Scenario confusion counts report true positives, false positives, true negatives and false negatives against the assigned experiment labels. Precision, recall, F1-score and false-positive rate are reported with denominators. The small development set does not provide population accuracy. Rule alert presence and ML review priority are separate outcomes; lowering priority does not suppress a rule alert.

3.7.1 Classification definitions and complete case reporting

For the declared binary scenario outcome, a true positive is a simulated abuse role with at least one qualifying positive decision; a false negative is a simulated role without one. A false positive is a benign role with a positive decision, and a true negative is a benign role without one. The qualifying decision depends on the stated method. V6 uses the presence of an online stage, whereas the context comparison uses an actionable review after permission processing. The underlying V6 event history remains available even where that second outcome changes. This definition is essential when comparing a raw suspicion detector with a review disposition.

Precision is TP divided by the sum of TP and FP and describes the fraction of positive cases carrying the simulated role label. Recall is TP divided by the sum of TP and FN and describes coverage of those labelled cases. Specificity is TN divided by the sum of TN and FP; the false positive rate is FP divided by the same benign denominator. F1 is twice TP divided by the sum of twice TP, FP and FN. Accuracy is the sum of TP and TN divided by

all classified cases. Balanced accuracy is the mean of recall and specificity. A ratio with a zero denominator is undefined and is retained as such rather than replaced by a perfect or zero score.

These descriptive statistics depend on the constructed class mixture and the complete cases accepted by the experiment. Six benign and six simulated cases give the fresh comparison equal class counts, so ordinary and balanced accuracy happen to coincide. That equality is a property of this set, not evidence of equal operational prevalence. One changed case moves the overall accuracy by one twelfth and a class specific rate by one sixth. Reporting the confusion counts makes this sensitivity visible and avoids suggesting that a percentage rounded to one decimal place has population level precision.

The comparison is paired at the case level: the same accepted episode can be positive under one method and negative under another. This makes the identity of changed cases more informative than comparing percentages alone. A contextual gain may result from reducing a benign alert, adding a destination violation or suppressing an allowed recovery that carries the simulated role. Reporting these transitions explains the practical tradeoff. The small set is not used to establish statistical superiority across deployment populations, and no uncertainty claim is inferred merely from the equality or difference of rounded summary metrics.

The early pilots use OFF, INTERNAL and EXTERNAL configurations in two counterbalanced blocks. The native module observes only authentication; the external rule-only comparison forwards the same authentication event family. Process CPU counters and RSS are sampled every 0.25 seconds. Samples around the traffic interval exclude preparation and offline extraction. Short-lived tails and shared memory limit these process observations.

3.8 Validity and Ethics

Internal checks preserve PCAPs, timestamps, source hashes, manifests and independent verification. External validity is limited by one generator, one PBX, constructed workloads, WLAN variation and small episode counts. Matched labels indicate assigned experimental roles, not independently observed criminal authorization. No production CDR baseline, real financial loss or autonomous mitigation result is claimed.

3.8.1 Validity protections and remaining uncertainty

The main internal validity protection is the separation of traffic generation, independent acceptance and prediction interpretation. The manifest specifies what should occur; the verifier checks what did occur; the evaluator records what the frozen method decided. Preserved captures and hashes make later changes detectable. These controls reduce the opportunity to explain away a miss by altering the workload label or to count an ungenerated call as a successful attack experiment. They do not remove all dependence on the researcher's design choices, because the accounts, permission matrix, timing patterns and experimental roles were constructed for the laboratory.

The matched profile design is especially important for construct validity. The study's intended construct is early suspicion of toll fraud, but its direct observations are protocol events and assigned roles. Holding observable patterns similar while changing the role exposes where the desired distinction is absent from those observations. A result that fails to separate the pair is therefore informative about the available evidence, rather than simply a reason to seek a more complex classifier. Independent policy can add another observable relationship, but an attacker operating within that policy can remain indistinguishable from an authorized user.

External validity is restricted by the two machine laboratory, two configured accounts, constructed routes and bounded traffic volumes. No measurement here estimates the false alert burden across an enterprise user population or the cost of an automatic response. The shared source controls test specific cardinalities, without establishing normal behaviour for a large group behind NAT. Repeated setup observations describe this network and these cases; they do not isolate WLAN variation or prove throughput at production concurrency. These qualifications define the population to which the findings apply and identify the evidence needed for a broader deployment claim.

3.9 Predeclared Permission Context and Common Evaluation

The final controlled extension freezes policy before collecting new traffic. The policy is a laboratory administrator record, independent of scenario intent labels. Table 3.5 states the account and destination permissions. A single time-bounded recovery permission covers account 1001 from the generator source, with at most eight confirmed failures. It contains no case ID or BENIGN/SIMULATED_ABUSE label. Account 1002 has no observed

recovery permission, although it is configured for registration and normal calls. The same permissions apply to benign and simulated-role cases, including matched pairs C003/C011 and C004/C012.

Table 3.5 Independent laboratory permission matrix

Account	Allowed source	Allowed destination	Recovery permission
1001	172.16.200.68	88001	Predeclared two-hour window; up to 8 failures
1002	172.16.200.68	88002	No recovery permission observed

The matrix is an emulated business policy rather than PBX route enforcement. Forbidden destinations are routed only to the isolated SIPp UAS for validation. No provider route or financial charge is involved. Unknown identity or missing permission remains unknown; a configured account does not prove who operated it.

The primary comparator counts ten transaction-confirmed failures within sixty seconds per source and account. A five-failure comparator uses the same sixty-second window as a frozen sensitivity check. Frozen V6 and V6 plus context receive exactly the same causally ordered SIP events. The common adapter exposes only packets at or before each event, preventing future INVITE identity or CDR outcome from entering a prediction. All raw V6 stages remain available even when contextual review changes an actionable-alert disposition.

Twelve new cases are predeclared: six BENIGN and six SIMULATED_ABUSE. Each method predicts before its assigned role is attached. Evaluation uses complete cases. Early warning means an alert strictly before the first generator INVITE; at-attempt alerts have zero lead and missed call cases remain in the denominator. Delays use causal replay event time, excluding live delivery latency. Models and thresholds remain frozen after traffic.

3.9.1 Fresh comparison protocol and information separation

The fresh comparison is organized around one observation stream and four frozen methods. The ten failure comparator represents a conservative threshold; the five failure comparator tests sensitivity to lowering that threshold; V6 adds state linked progression; and the context extension combines preserved V6 stages with independent permissions. Applying them to the same accepted cases removes differences in generated traffic as an explanation for their paired results. The comparison does not require equal internal complexity, but it

does require that each method receive only information available at its reported decision time.

The policy record is frozen before the new traffic and applies across both assigned roles. Account 1001 and account 1002 have their own allowed destinations, while only account 1001 has the bounded recovery permission. That asymmetry is deliberately visible and should not be mistaken for a learned estimate of user risk. It lets the experiment examine both permitted recovery and missing permission evidence. The predeclared role label is joined to the prediction only for evaluation and is not an input accepted by the context function. Matched benign and simulated cases therefore encounter the same policy when their source, account, destination and timing satisfy the same conditions.

The complete case analysis includes the direct destination violation case, recovery cases and cases without an outbound attempt. The five simulated role call cases form the separate early warning denominator; the authentication only simulated case belongs in classification but has no INVITE lead. Keeping these denominators distinct prevents a method from gaining apparent pre call coverage from an experiment in which no call was attempted. The four REGISTER cardinality controls are separately declared diagnostic checks and are not added to the six benign role cases to improve the reported false positive rate.

The policy and role separation also constrains interpretation of the control conditions. Calling a case benign describes its assigned role, while calling a destination allowed describes a relationship in the administrator record. Those are different variables, so an assigned benign case can still retain review when recovery permission is missing. Likewise, a simulated role can satisfy the allowed destination and recovery conditions. Preserving both combinations avoids defining truth directly from the same rule that makes the prediction. It also makes clear that the experiment tests the value and limits of recorded context, rather than an infallible external label of legitimacy.

Chapter 4 System Design and Implementation

The implemented system combines a protocol adapter, entity histories, an interpretable progression engine and optional causal review priority. V2 to V6 are research iterations, not released product versions. The frozen V5 and V6 scripts remain intact; later online and burst extensions use separate files.

4.1 Detector Evolution and Rationale

Table 4.1 Research detector evolution

Iteration	Change	Reason or boundary
V2	Early SIP extraction and staged prototype	Establish request and response visibility
V3	Windowed request and response counts	Interpretable rapid-traffic baseline
V4 evaluation	Explicit scenario IDs and boundary analysis	Avoid merging adjacent scenarios; expose slow and sub-threshold misses
V5	Transaction-matched confirmed digest rejection and longer auth window	Normal 401 challenges are not rejected credentials
V6	Link source and account across failure, recovery and lab call evidence	Represent progression while preserving suspicion semantics
Separate online extension	Normalized events, rule service, causal priority and distinct-call burst	Observe live decisions without rewriting frozen replay artefacts

4.2 Confirmed Authentication and Reconnaissance

V5 matches requests and responses using Call-ID, CSeq, method and reversed addresses. A normal initial challenge does not count as a failed password. An authenticated rejection is confirmed after a one-second retry grace; stale challenges and successful retries are excluded. Figure 4.1 shows why raw response counts can overstate attempted credential failures.

4.2.1 Transaction matching and rejection confirmation

The authentication parser associates a response with a preceding request using Call ID, CSeq number, method and reversed source and destination addresses. This association is more specific than counting response codes by source address alone. A request can receive an ordinary challenge and then be retried with digest authentication. The initial challenge shows that authentication is required; it does not show that a submitted password failed.

The parser consequently checks whether digest credentials were present on the matched request and whether the challenge was marked stale before considering a rejection as evidence of a failed credential submission.

An authenticated 401 or 403 response creates pending rejection evidence rather than an immediate confirmed failure. The one second retry grace allows a successful response in the same tracked dialog to cancel that pending item. A stale challenge is excluded, and repeated or unmatched responses do not automatically create additional failures. The archived parser also records unresolved pending items at the observation boundary. This design makes the temporal meaning of a confirmed failure explicit: it is a qualified interpretation of a matched exchange after the grace condition, rather than a raw packet count.

The parser's safeguards remain bounded by its implemented transaction and observation rules. They do not establish correct handling for every SIP extension, authentication mechanism, packet loss pattern or concurrent endpoint topology. Retransmission filtering and the distinction between initial and authenticated requests are tested with the supplied cases, while the retained B024 anomaly demonstrates that repeated authenticated traffic can still affect exact count acceptance. For this reason, protocol normalization is reported as an implemented laboratory mechanism with auditable counters. It is not represented as a universal authentication oracle for all PBX deployments.

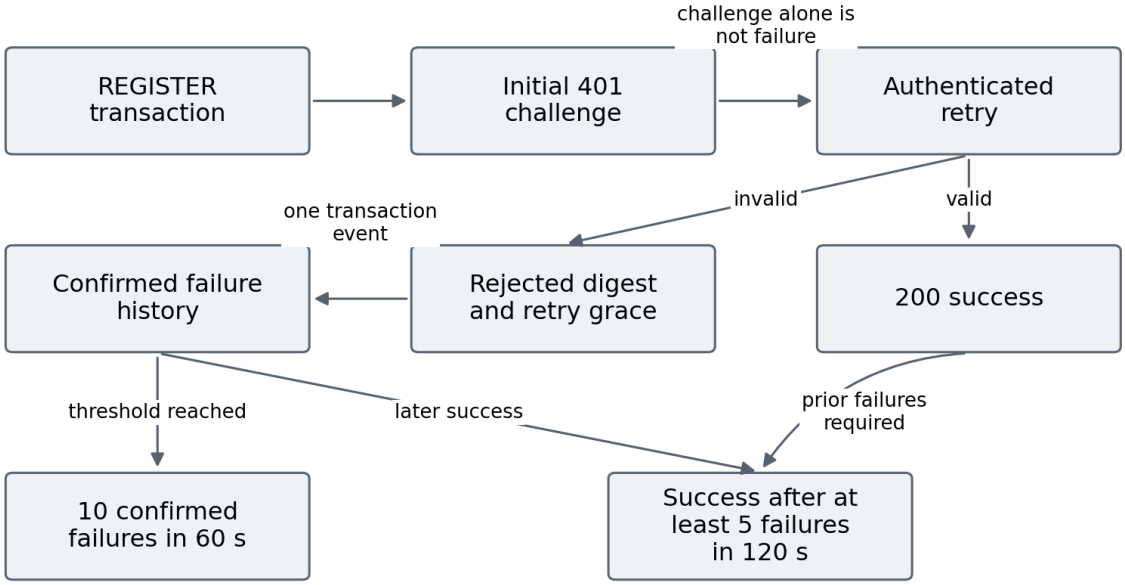


Figure 4.1 Confirmed authentication failure and recovery logic

The V6 reconnaissance rule tracks distinct OPTIONS targets rather than treating every OPTIONS message as malicious. Five distinct targets within ten seconds generate the reconnaissance stage. The authentication stage requires ten confirmed rejections in sixty seconds. These development thresholds are explicit experimental settings, not universal operational limits.

4.2.2 Entity histories and stage state

The progression engine maintains different histories for different questions. Reconnaissance uses recent distinct OPTIONS targets for a source. Authentication accumulation uses confirmed failures for a source and account, avoiding the assumption that every account behind one address belongs to the same episode. Recovery suspicion uses the longer 120 second failure history and a successful registration for the same key. These histories allow a sequence to be interpreted through its relations and timing. The engine therefore explains why a stage was emitted, rather than assigning suspicion solely because one request or one response code appeared.

A stage name describes a threshold satisfied by observed evidence. RECONNAISSANCE means that the configured target diversity condition was reached. AUTHENTICATION_ATTACK means that the configured confirmed failure condition was reached. SUSPECTED_COMPROMISE means that valid registration followed a

sufficient recent failure history. None of these names independently proves the external circumstance suggested by the label. In particular, the recovery transition can be generated by an authorized user correcting a password. Retaining the suspected qualifier and the evidence reason preserves the distinction between an interpretable alert and a verified security incident.

The state is also time bounded. Pruning old entries prevents a failure that lies outside the declared history from contributing indefinitely to the next recovery decision. Linking a subsequent call within 120 seconds expresses a configured temporal relationship, not an assertion that every later call by that account belongs to the same cause. The thresholds were chosen during development and frozen for the stated tests. Their transparency supports reproduction and critique, while the experiments do not establish them as optimal settings for a provider, enterprise or population with different traffic patterns.

4.3 Recovery and Linked Call Progression

V6 stores failures per source IP and account. A successful registration after at least five failures in 120 seconds emits SUSPECTED_COMPROMISE. A linked lab INVITE within the next 120 seconds emits SUSPECTED_OUTBOUND_ATTEMPT. Subsequent SIP completion and independently added CDRs support ANSWERED_EMULATED_OUTBOUND in archived analysis. A valid registration proves credential acceptance, not theft.

The separate burst extension emits CALL_BURST on the third distinct lab INVITE within sixty seconds. Repeated packets for the same call are not extra calls. As shown in Figure 4.2, the burst stage uses attempts at event time, while SIP completion and CDRs are later corroboration. CALL_BURST does not imply a premium destination or verified unauthorized expenditure.

4.3.1 Call attempts completion and distinct call counting

The linked outbound stage concerns an INVITE attempt after eligible recovery suspicion. The event is useful precisely because it can occur before the call outcome is known. An INVITE retransmission is not a second call, and a later success response is not evidence that a distinct second attempt occurred. The separate burst extension therefore counts distinct lab call identifiers for its three attempt threshold. A burst alert remains an observation of concentrated calling. The benign smoke scenario shows that a configured

number of legitimate calls can also satisfy that condition, so burst presence alone cannot establish fraud intent.

Completed call evidence is evaluated separately. A successful INVITE response together with ACK and BYE observations supports the signalling interpretation of a completed generator leg. An added answered CDR provides independent PBX reporting evidence of the isolated call. These checks make the experiment stronger than an evaluation that counts only sent INVITEs, because a client can generate requests without completing any conversation. However, they remain retrospective checks and cannot be supplied as features to a decision claimed to precede the first INVITE. Their role is validation of the experiment and later interpretation of the progression.

The distinction also limits financial conclusions. The laboratory destination routes terminate at the SIPp user agent server and are removed after testing. An answered emulated outbound call is therefore a controlled demonstration of progression through calling, without provider billing or measured monetary loss. The system does not infer that a destination is expensive from the existence of a CDR, and the context layer's forbidden destination outcome describes a declared laboratory policy. These facts permit reproducible testing of dangerous patterns while keeping the contribution focused on observable behaviour rather than an unmeasured cost prevention claim.

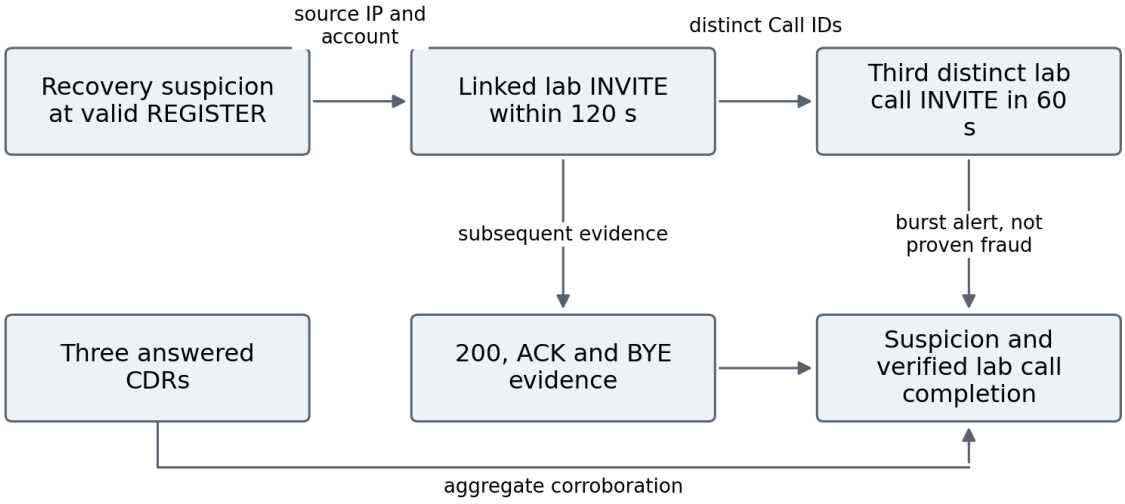


Figure 4.2 Recovery call attempts and independent completion evidence

4.4 Lightweight Review Priority

The frozen logistic model standardizes the four causal features, applies the saved coefficients and produces a score. A score below 0.4 is LOWER priority, 0.4 to below 0.6 is REVIEW, and at least 0.6 is HIGHER. These categories add review metadata to the rule result. The score is not a calibrated probability of real-world fraud, and no category automatically blocks or hides the alert.

The model file records training IDs, feature statistics, coefficients and hashes. The live ML service was separately validated with B016 using the frozen file. That validation confirms delivery of the score, rather than demonstrating that the score distinguishes matched authorization roles.

4.4.1 Causal score interpretation and review metadata

The logistic score is applied after standardizing the four available features with the frozen development means and scales. The saved linear coefficients and intercept produce one bounded score, which is mapped to LOWER, REVIEW or HIGHER using the declared cut points. This makes the computation reproducible and keeps the contribution of the features inspectable. It does not provide a calibrated operational probability that a registration belongs to a fraudster. Calibration would require an appropriate target population and an independent assessment of predicted probabilities against outcomes, neither of which is supplied by the matched laboratory role experiment.

Review metadata and a binary alert answer different operational questions. V6 can identify a recovery pattern while the score suggests how that pattern might be prioritized. Because LOWER does not suppress the underlying stage, an equal number of rule alerts can remain visible even when score categories differ across profiles. Conversely, a HIGHER score in an authorized case is not a software delivery failure; it is a classification limitation of the available features and model. Reporting the score, category and unchanged rule outcome together prevents priority assignment from being misreported as an automatic prevention result.

The frozen matched evaluation is designed to make this distinction testable. Opposite assigned roles share the relevant signalling profile, so a model restricted to that history has no guaranteed information with which to separate them. Slight score differences from timing variation do not establish meaningful role discrimination when the pair remains in

the same category. Live score delivery validates that the same frozen computation can accompany an alert. It does not reverse the negative discrimination finding or justify retuning the threshold after seeing the evaluation labels.

4.5 Internal and External Realizations

The internal C module was compiled for the Pi Asterisk 20.6.0 build and installed. It subscribes to restricted security events from the lab generator and accounts 1001 and 1002. It has no call-control code. Live auth-only A000 to A002 validated a normal registration, ten failed passwords, and six failures followed by valid registration. The module was unloaded after testing.

The external process accepts normalized lab events over loopback. A capability-enabled tcpdump streams restricted packets into tshark; the collector forwards relevant fields to the service. Figure 4.3 defines the earlier shared-authentication delivery paths. That first pilot excluded ML and call stages. The later five-stage native observer and external path were tested separately in B030 to B036, as reported in Section 5.9.

4.5.1 Deployment paths and comparable functionality

The native path observes selected Asterisk events inside the PBX process, while the external path receives normalized information through a collector and service. Their placement changes the route between a network event and an observable output. The early shared authentication comparison deliberately restricts the forwarded event family so that the external service is not credited with call stages unavailable to the native authentication module in that pilot. A later five stage comparison is a separate extension with a broader shared capability. Keeping the two pilots distinct avoids treating the existence of two executable paths as proof that every function was compared under identical conditions.

The external observation chain includes capture, packet decoding and communication with the service. The service's own handling interval consequently describes only part of end to end alert availability. A fast decision after event receipt can coexist with a much slower packet to reply interval if capture delivery or decoding is delayed. The native observed log endpoint also includes logging and polling rather than an idealized instant at which a branch of C code executes. Naming these endpoints makes the reported differences interpretable without attributing every millisecond to the underlying detection rule.

Both paths are passive observers in the measured experiments. The module contains no call control action, and the service's output is review information. Unloading the observer and checking for zero active calls and absent temporary routes are cleanup conditions; they are not demonstrations of automated mitigation. This boundary is important for maintainability and operational practicality. A prototype can show that events and scores are delivered through two integration paths while leaving upgrade compatibility, concurrent load, long duration stability and the consequences of a false blocking decision for separate evaluation.

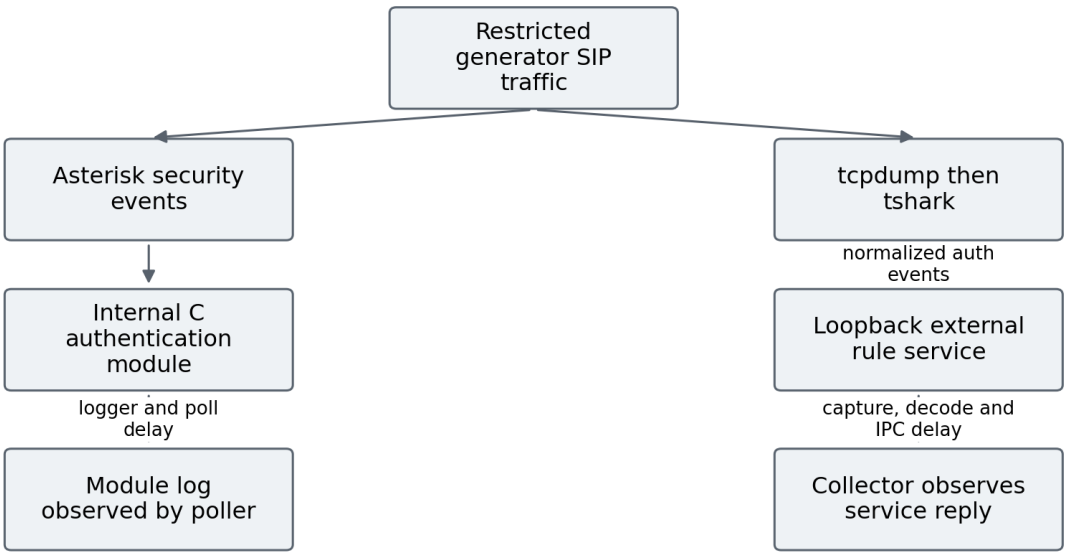


Figure 4.3 Shared authentication deployment paths and observation endpoints

4.6 Reproducibility and Implementation Boundaries

Every run retains source hashes and its declared manifest. The online adapter replay matched the frozen ordered V6 stages in 34 of 34 saved runs, covering 253 adapted events and 37 alerts. This is a compatibility check on inspected captures, not a new predictive evaluation or proof of live latency.

CDR snapshots preserve a before-prefix and identify added answered calls for the controlled route. The later native observer covers five online stages in a bounded pilot. Production calling priors, robust concurrent SIP-to-CDR linkage, automatic mitigation and production load testing remain outside the measured implementation.

4.6.1 Reproducibility records and limits of replay

The evidence record preserves several layers because a result cannot be reproduced from a final percentage alone. The manifest identifies the declared case and workload. Packet and authentication records support the event interpretation. CDR snapshots support completed call acceptance. Frozen source and model hashes identify the logic applied. Per case predictions retain which method emitted which stage and when. Result summaries then aggregate these recorded decisions. Preserving this chain allows a reader to trace an aggregate change to the cases responsible rather than relying on an unexplained score table.

Hashes establish consistency between a retained file and its recorded identity. They can detect that a source, policy, manifest or capture differs from the frozen version. They do not prove that a label was appropriate, that an operating system clock was exact or that an omitted experiment would have produced the same outcome. Similarly, deterministic reproduction of saved predictions establishes that the analysis can be repeated over the preserved inputs. It does not turn the original controlled cases into a second prospective dataset or independently validate the premises of the permission policy.

Portability therefore requires both the files and a description of their interpretation. A relative directory points to a result family, while the family description identifies whether it is development, inspected replay, fresh prediction or live deployment. Overlapping captures must retain their common identity across those roles. The saved 34 run compatibility check is useful because it verifies stage ordering across an adapter, but those captures were already inspected. Its perfect replay agreement is evidence about implementation compatibility, not an independent estimate of future sensitivity or a substitute for live delivery measurements.

Interpreting the evidence index requires the same separation between research phases. The historical detector sources, causal model configuration, common evaluator, permission record and fresh result summary have different roles and need distinct identities. In particular, an archived decision tree file cannot substitute for the later logistic model simply because both belong to machine learning work. A source or model hash is meaningful only in conjunction with the experiment and configuration to which it refers. This distinction helps a reader reproduce the intended comparison and recognize when a different retained file belongs to another analysis.

4.7 Permission Layer and Causal Replay Implementation

Figure 4.4 shows the separate context extension. The original V6 source remains frozen at SHA-256 c4b9231a89a815e93f1264119e229df1a563d574ba4b6a7e357d8125983eb2b4. The evaluator invokes that unchanged logic on each causal prefix, substitutes an empty CDR view, and records online stages only. A parity assertion compares those stages with the original offline evaluator after prediction. This descriptive verification does not feed CDRs into the detector.

4.7.1 Causal prefix evaluation and information leakage controls

The common evaluator presents the frozen progression function with one successive prefix at a time. At each timeline event, only packet rows whose timestamps are already available enter the packet view, and only the current timeline prefix enters the event view. This is necessary because a full archived capture can contain information that the original offline function would otherwise inspect before it was causally available. An account mapping inferred from a later INVITE, for example, must not help interpret an earlier event merely because both are present in one file.

The adapter also supplies an empty CDR view during online prediction and restricts accepted outputs to the specified online stage set. A retrospective answered stage is therefore excluded even when the preserved run contains completed call records. Emitted events are retained once using their stage, time, source, account and call identifier, rather than repeatedly counted because the function is invoked on a growing prefix. These implementation choices allow the unchanged V6 logic to be assessed at the stated decision boundary while retaining the original source identity for comparison.

A subsequent parity assertion checks the online stages against the frozen offline evaluator after prediction. The order of those operations matters: verification can inspect the complete saved record to establish correspondence, but it must not provide future information to the prediction that is being verified. This is an analysis separation rather than a claim that offline and live execution have identical runtime costs. The repeated prefix procedure is a deterministic evaluation mechanism; its elapsed processing time is not reported as the latency of the live external service or the native observer.

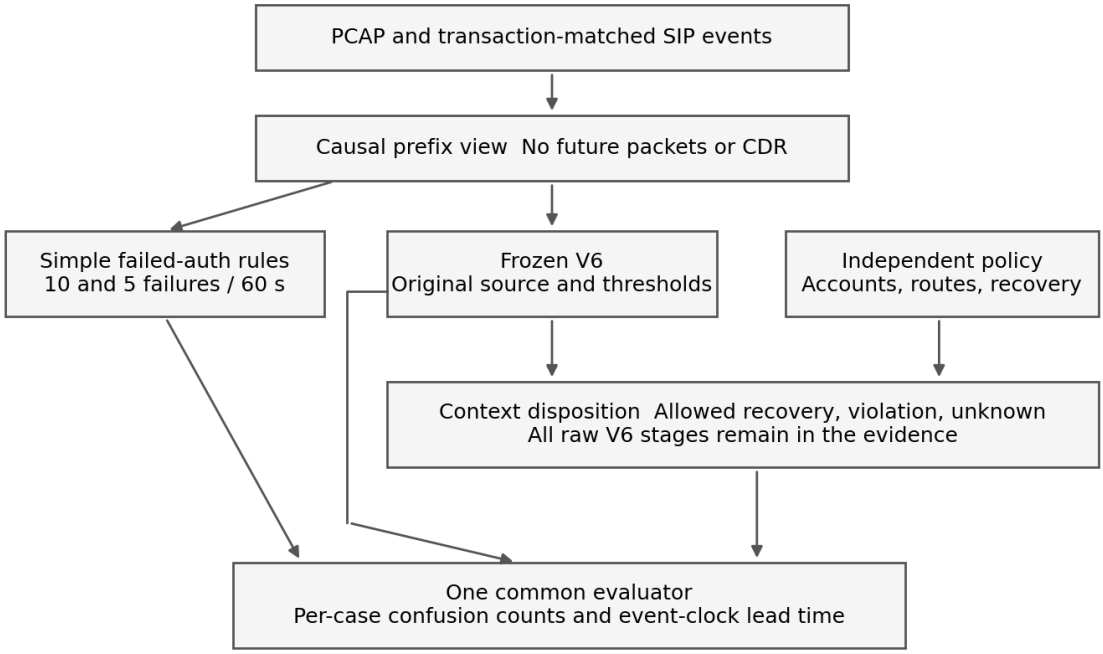


Figure 4.4 Frozen stage logic and independent context in the common evaluator

The permission layer retains reconnaissance and authentication-attack review. For recovery and linked-call stages, it checks source/account permission, the predeclared recovery time window, failure allowance and destination policy. Allowed recovery receives an authorized_recovery_review disposition. Missing evidence retains actionable review. Every observed INVITE outside a known account destination allowlist additionally emits DESTINATION_POLICY_VIOLATION, even if V6 emitted no preceding stage.

4.7.2 Permission outcomes and actionable review semantics

The permission function first asks whether the source is recognized for the account. For a recognized account source pair, registration permission and allowed destinations can be checked against the fixed record. If the required identity or source relationship is absent, the outcome remains unknown. Recovery permission is a separate condition with an inclusive validity interval and an upper bound on confirmed failures in the preceding 120 seconds. It is not supplied by the successful registration itself. This distinction prevents credential acceptance from becoming circular evidence that the preceding recovery was authorized.

Only recovery and linked outbound stages that meet both the allowed policy outcome and the bounded recovery condition receive the authorized recovery review disposition. Reconnaissance and authentication attack evidence remain actionable, and missing

permission does not erase an alert. Every raw stage is preserved for inspection. The binary context comparison then tests the presence of actionable review rather than deleting the original observations. As a result, a lower false alert count means that fewer benign cases retained that disposition under the declared policy; it does not mean that the signalling detector saw a different packet sequence.

The destination check also examines observed distinct INVITEs and can add a destination policy violation without a preceding recovery stage. This supplies a specific route to detect direct use of valid credentials for a forbidden laboratory destination. Its warning occurs at the attempted INVITE, because the destination is observed then. The same mechanism cannot resolve an operator's hidden role when the source, account, recovery window and destination all comply with policy. The matched allowed case is retained to show this ambiguity explicitly instead of assuming that policy agreement proves benign intent.

Ten implementation checks cover initial unauthenticated 401 responses, separate accounts sharing one IP, expiry of failures, frozen-stage progression, authorized recovery, forbidden destinations, missing recovery context, future packet leakage, indistinguishable hidden roles and undefined metric denominators. The checked code and permission matrix are hashed before the fresh batch. Portable read-only reproduction subsequently matches every prediction and confusion count in all twelve cases.

4.7.3 Implementation checks and bounded assurance

The implementation checks target failure modes that would invalidate the experimental comparison. Initial unauthenticated challenges must not become password failures. Accounts sharing a source must retain separate histories. Expired failures must cease contributing to a current decision. Future packet information must not alter an earlier prediction. Missing recovery evidence must not be treated as affirmative authorization, and an undefined metric denominator must remain explicit. These checks protect the meaning of the measured outcomes. They are distinct from asking whether the final detector achieves an acceptable production detection rate.

The hidden role check has a different purpose from a conventional positive detection test. When two cases provide the same observable conditions but different assigned roles, the implementation should not acquire a difference by reading a case identifier, label or future outcome. Preserving indistinguishability is therefore a correctness condition for

information separation even though it produces a false negative or false positive in the role classification. It makes the limitation attributable to the observation boundary, rather than to accidental access to an answer embedded in the experiment's metadata.

Taken together, the checks support a bounded claim that the frozen comparison operates on the intended inputs and preserves the specified semantics. They do not establish complete software security, exhaustive SIP coverage or robustness against every adversarial strategy. A new environment would require additional protocol, load and failure testing, together with independent permissions and normal operating histories. The present implementation is consequently evaluated as an auditable research prototype whose decisions can be explained and reproduced, with the limits of its evidence carried forward into the conclusions.

Chapter 5 Results and Discussion

Results are organized by evidence family so that event metrics, development scenario coverage, fresh causal evaluation and deployment timing retain their own denominators. A suspicion alert is evaluated against an assigned role but is not presented as proof of credential theft.

5.1 Earlier Loopback Baseline and Boundary Findings

The earlier labelled Python loopback benchmark used fixed rapid request blocks. All three attack-labelled blocks were detected in eleven repeated runs. Tables 5.1 and 5.2 retain those historical results. The reported FRAUD_BURST label concerns generated INVITE patterns and is not evidence of answered provider calls. These event-level results cannot be compared directly with the later F-series scenario-level metrics.

Table 5.1 Historical loopback scenario timing

Stage	Detection rate	Mean TTD (s)	Median TTD (s)	Range (s)	SD (s)
Reconnaissance	11/11 (100%)	1.8647	1.9554	1.4934–2.2792	0.2211
Authentication attack	11/11 (100%)	2.2866	2.3128	1.8869–2.5398	0.1972
Fraud burst	11/11 (100%)	0.8244	0.8238	0.6724–0.9470	0.1001

Table 5.2 Historical loopback event metrics

Metric	Mean across stored baseline runs
Precision	1.0000
Recall	0.7111
F1-score	0.8312
False-positive rate	0.0000

The twelve-scenario boundary experiment detected three of eight attack-labelled cases and avoided alerts in four controls. Below-threshold and low-and-slow cases were missed. This motivated the longer confirmed-failure history and explicit progression rather than claiming the rapid baseline represented broad robustness.

5.1.1 Interpretation of the successive evaluation families

The contrast between the rapid loopback benchmark and the boundary experiment explains why the study did not retain a single headline detection rate. The loopback runs asked whether a fixed generated sequence could repeatedly activate the intended thresholds. The boundary cases asked what happened when timing, intensity and scenario structure moved outside that narrow sequence. Successful repetition of the first workload and substantial misses in the second can both be correct. They answer different questions about deterministic operation and workload coverage. Treating the eleven repeats as eleven independently sampled attacker behaviours would conceal that distinction and exaggerate the breadth of the evidence.

The boundary misses also identify the engineering purpose of the later revisions. A short burst threshold can respond quickly when its required observations arrive together, while a slower sequence may never accumulate enough evidence within that window. Extending the confirmed-failure history changes the observations retained for a decision; it does not create evidence that was never captured. Similarly, linking a later successful registration to earlier failures can recover a progression that a request-count method overlooks. The gain is a more complete account of selected sequences, accompanied by the possibility that legitimate recovery follows the same sequence.

The F-series comparison should therefore be read as a development argument about these design choices. V6's additional coverage is consistent with the explicit rules that were added, and the benign recovery alert reveals the cost of applying those rules to an ambiguous case. This makes the false alert part of the explanation of the model rather than an incidental exception. The development exercise supports the relevance of transaction semantics, longer histories and entity linkage. It cannot establish the frequency with which those benefits and costs would arise in an operational population that was not sampled.

The successive evidence families collectively show methodological refinement without forming a single growing statistical sample. Replaying an inspected trace, generating a matched profile and running a new deployment case each contributes a different form of evidence. The correct synthesis is that the architecture became more precisely specified and its failure boundaries became more visible. The research does not infer a continuous improvement curve from percentages calculated over changing units, labels and

observation endpoints. That separation is necessary for the later permission experiment to be interpreted as a distinct test of additional information.

5.2 Registered Scenario Coverage

The F01 to F12 development set contains six benign and six simulated attack scenarios. Table 5.3 shows that V6 flagged all six simulated cases and one benign recovery case. The false-positive rate is one of six benign scenarios, not one of twelve total cases. The set was used during detector development and is not a new holdout.

Table 5.3 F-series scenario confusion counts and metrics

Detector	TP FP TN FN	Precision	Recall	F1	FPR
V3	4 2 4 2	0.667	0.667	0.667	0.333
V5	5 1 5 1	0.833	0.833	0.833	0.167
V6	6 1 5 0	0.857	1.000	0.923	0.167

V6 improves coverage on this set, but its benign recovery alert exposes an intent boundary. Authorized users who recover from repeated wrong passwords and simulated unauthorized users with the same SIP sequence can produce the same evidence. This is the reason for using suspected-stage names and preserving administrator review.

5.3 Common Onset Archived Timing

The timing audit uses the first captured request as a common onset for F05 and the six simulated attack cases. Table 5.4 reports the first alert of any stage. It is an archived policy-time comparison; the first alerts can differ in stage and risk. A dash indicates no alert.

Table 5.4 Archived seconds to first alert from a common onset

Case	Assigned truth	V3	V5	V6
F05	Benign	9.785	—	16.298
F07	Simulated attack	4.004	4.004	4.004
F08	Simulated attack	5.243	5.243	5.243
F09	Simulated attack	4.007	10.006	10.006
F10	Simulated attack	—	29.853	29.853
F11	Simulated attack	8.057	—	13.619
F12	Simulated attack	—	29.770	29.770

Reconnaissance timing is equal in F07 and F08. V6 alerts later than V3 in F09 and F11; confirmed-rejection semantics and stage requirements explain why the first-any-alert endpoint alone is not a quality measure. F10 and F12 are covered by V5/V6 but missed by V3. Universal earlier detection is therefore not demonstrated.

Recovery review precedes the first linked INVITE by approximately 1.70 seconds in simulated F11/F12 and 1.72 seconds in benign F05. This is useful pre-call suspicion, but it does not satisfy a claim of verified fraud or automatically count as the proposal high-risk endpoint. H1 is not supported as a general earlier-detection claim.

5.3.1 Meaning of an early warning advantage

An early warning has at least two relevant coordinates in this study: the moment at which sufficient behavioural evidence exists and the moment against which that warning is judged. Time from the first captured request measures how long a rule waits while the sequence develops. Lead before the first linked INVITE measures whether suspicion is available before the observed calling attempt. These quantities are related but are not interchangeable. A detector can take longer from the initial request yet still warn before calling, while an earlier low-specificity alert can occur without identifying the later account or destination.

The common-onset comparison controls the first coordinate more carefully than comparisons using different starting packets. It still does not equalize the meaning of the first alert. A reconnaissance alert, an authentication threshold and a recovery review embody different evidence requirements. Their first-any-alert times describe policy behaviour rather than a universal scale of threat confidence. Consequently, an earlier alert from a simple baseline cannot be dismissed merely because its model is simpler. Equally, a later stage decision cannot be described as more accurate solely because it incorporates a longer sequence. Timing and classification must be assessed together.

The first INVITE is a practical, observable boundary in the isolated laboratory route, but it is not an independently measured onset of financial loss. The completed laboratory calls establish that the scripted calling path worked. They do not establish provider charging, destination cost or the time at which an operator could have prevented a loss. The study therefore reports pre-call suspicion and at-attempt policy review. Claims about money

saved, prevented fraud or operational intervention time would require additional endpoints that were not measured here.

This interpretation also affects H1. The hypothesis proposes an advantage over basic baselines, so the relevant evidence includes cases where those baselines warn earlier and cases where the progression engine covers a sequence they miss. The findings support a qualified benefit in sequence representation and selected coverage. They do not support a general earlier-warning advantage. Retaining the negative comparison gives a clearer answer to the research question than redefining early detection after observing which endpoint favours V6.

5.4 Frozen Causal Model Evaluation

The fresh B006 to B015 evaluation contains five matched profiles with opposite assigned roles. Each case has three completed lab calls and three answered CDRs, giving thirty independently checked calls. The model uses only the four causal features at REGISTER success. Table 5.5 pairs the scores by profile, and Figure 5.1 makes their near-overlap visible.

Table 5.5 Opposite role scores from the frozen causal model

Authorized	Score	Simulated role	Score	Both priorities
B006	0.3969	B011	0.3971	LOWER
B012	0.4708	B007	0.4716	REVIEW
B008	0.5385	B013	0.5382	REVIEW
B014	0.5760	B009	0.5830	REVIEW
B010	0.7336	B015	0.7327	HIGHER

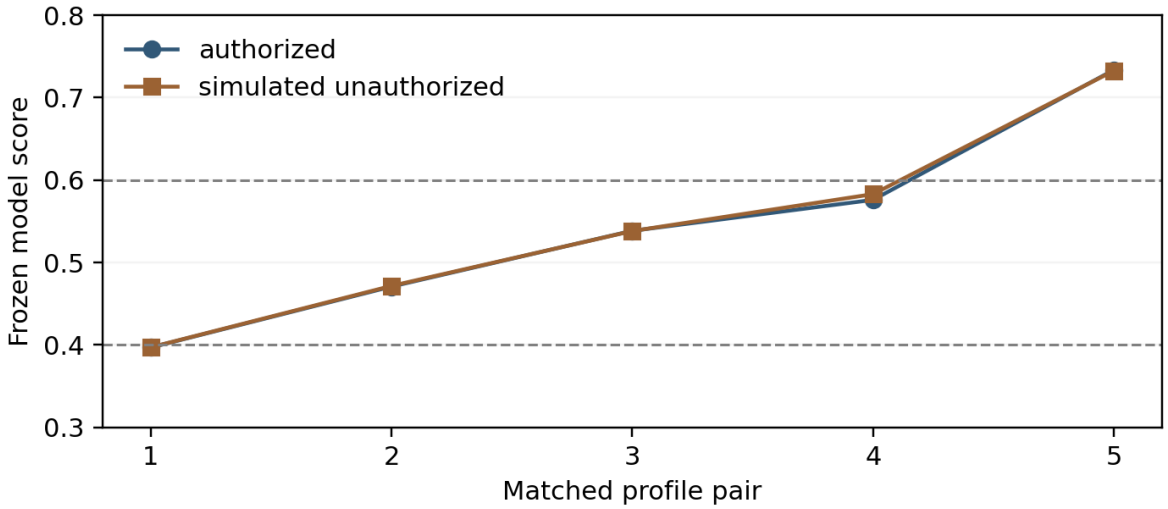


Figure 5.1 Frozen model scores on five matched profiles

Every matched pair receives the same priority category. LOWER contains one authorized and one simulated case; REVIEW contains three of each; HIGHER contains one of each. At the higher-priority threshold of 0.6, precision is 1/2 and recall of the five simulated roles is 1/5. These describe a priority subset, not automatic blocking or a population fraud classifier.

Rule recovery alerts remain visible in all ten cases. The model therefore demonstrates integration and a reproducible negative result: no separation of the assigned intents and no false-alert reduction were established. H2 is not supported. Independent authorization, destination policy or historical behaviour would be required to supply information absent from the matched SIP profiles.

5.4.1 What the matched profiles reveal about machine learning

The matched-profile evaluation isolates an information problem that aggregate classification scores can obscure. Within each pair, the intended difference is the assigned authorization role, while the model receives closely matched observable registration behaviour. The scores consequently remain close and the priority category is unchanged. This is not evidence that the implementation failed to execute the saved model. The unchanged coefficients, causal scoring event and retained outputs instead make the failure to separate roles reproducible. The result shows that the selected features do not carry enough information to identify the role distinction under the constructed matching conditions.

A different classifier could change the shape of its decision boundary, but the present experiment offers no basis for expecting that change alone to recover information absent from its inputs. More complex learning is therefore not a justified conclusion from this negative result. A better next question concerns which independently available observations distinguish the two roles. Destination permission and approved recovery are examples examined separately in the context experiment. They change the information available to the decision process, whereas merely replacing the model would change how the same information is transformed.

The priority thresholds also need to retain their operational meaning. HIGHER selects two cases in the matched evaluation, one of each role. It does not create an action-ready subset in which unauthorized use has been verified. LOWER likewise includes a simulated role and should not be used to erase the underlying recovery evidence. Keeping all rule alerts visible avoids interpreting a low model score as permission. This separation between observed event, model priority and administrative disposition is an architectural benefit even though the experiment does not demonstrate a classification improvement.

H2 accordingly remains unsupported for the frozen causal model. The study evaluated a concrete refinement mechanism and obtained a negative finding about its incremental value for the chosen distinction. That answer is more specific than a statement that machine learning is generally ineffective. Other features, different independent labels or another operational task could produce a different outcome, but those possibilities require new evaluation. The separate context improvement cannot be counted as confirmation of H2 because no learned model produced that improvement.

5.5 Live Integration and Shared Authentication Delivery

Live case B016 verified six rejections, valid registration, three completed calls and the unchanged ML review score of 0.4733. Its five live alerts had observed packet-to-decision median 362.630 ms and range 112.713 to 942.540 ms; median service handling was 0.122834 ms. The difference separates capture and delivery from service computation. One case is not a latency distribution.

T001 to T006 then compared the shared authentication stage without calls or ML. OFF generated no review, and each enabled case generated one review. Table 5.6 reports authenticated successful REGISTER request to observed alert availability.

Table 5.6 Shared authentication observed alert availability

Case	Mode	Observed availability ms
T001	OFF	—
T002	INTERNAL	1.790
T003	EXTERNAL	274.645
T004	EXTERNAL	574.066
T005	INTERNAL	1.808
T006	OFF	—

The internal endpoint is when a poller sees an Asterisk module log line, including logger delivery and two-millisecond polling. The external endpoint is when the collector sees a service reply, including capture, decoder and IPC delay. The two internal observations are lower on this Pi, but they are not exact decision timestamps or a controlled comparison of complete detector algorithms. H3 receives limited pilot support for observed delivery latency only.

5.6 Call Setup and Resource Pilot

The separate call pilot uses the same six-failure recovery profile and three sequential SIPp UAS calls per case. Six accepted cases provide eighteen distinct completed calls and eighteen answered six-second CDRs. Seven cases were attempted overall, giving twenty-one calls including the excluded B024. B024 produced a repeated authenticated REGISTER with the same Call-ID and CSeq 2 and seven auth log lines. The original exact-count gate failed, so B024 was retained, B025/B026 were not run, and B027/B028/B029 were declared as a replacement block.

As shown in Table 5.7 and Figure 5.2, setup medians vary across cases. The start is the first generator INVITE and the end is the first PBX INVITE 200 response for the same Call-ID, including authentication. Calls within a case are clustered observations, not eighteen independent deployment replications.

Table 5.7 Accepted call setup cases

Case	Mode	Block	Median ms	Three calls ms
B021	OFF	1	45.972	19.879, 45.972, 55.738
B022	INTERNAL	1	16.100	16.100, 84.192, 13.037

Case	Mode	Block	Median ms	Three calls ms
B023	EXTERNAL	1	26.004	11.087, 26.004, 51.898
B027	EXTERNAL	2	78.351	78.351, 40.644, 124.027
B028	INTERNAL	2	35.571	35.614, 35.571, 14.649
B029	OFF	2	54.484	54.484, 16.750, 56.377

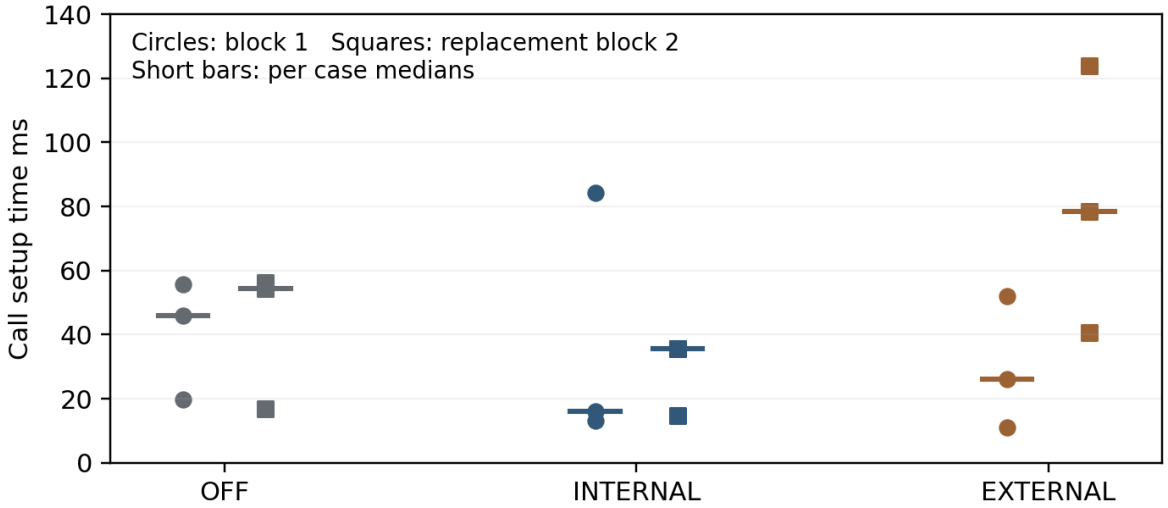


Figure 5.2 Individual call setup times and per case medians

Table 5.8 Within block setup differences relative to OFF

Block	Enabled mode	Enabled minus OFF median ms
1	INTERNAL	-29.872
1	EXTERNAL	-19.968
2	INTERNAL	-18.913
2	EXTERNAL	+23.867

The external difference changes sign between blocks. Lower internal medians do not demonstrate a speed improvement because this small nonrandomized WLAN pilot cannot isolate network and host variation. No consistent causal overhead effect or production acceptance threshold is established.

Table 5.9 Process observations during accepted call traffic

Process	CPU percent of one core	Peak RSS MiB
Asterisk PBX	0.202 to 0.231	94.73 to 96.23

Process	CPU percent of one core	Peak RSS MiB
External collector	0.050 to 0.076	17.22 to 17.41
External rule service	0 to 0.025	17.47 to 17.67
External tshark decoder	0.025 to 0.051	151.97 to 152.97

Sampling uses the first generator REGISTER through the last generator-leg BYE plus 0.5 seconds. Startup and offline extraction are excluded. Zero CPU means below sampling resolution; process tails may be missed and RSS may count shared pages. PBX memory rises between blocks across modes and is not attributed to the native module. Kernel, WLAN and whole-system costs are not isolated.

5.6.1 Operational interpretation of the deployment observations

The deployment pilots establish that observation can be realized through two integration paths, while exposing the measurement boundaries of each path. The native observer receives selected PBX events inside the process. The external path adds packet collection, decoding, event transfer and service response. The observed alert availability therefore includes a sequence of mechanisms rather than only the time spent evaluating a rule. The substantial difference between service-handling time and packet-to-decision time in B016 illustrates why optimizing the classifier alone would not necessarily produce an equivalent improvement in end-to-end availability.

Call setup measures a different consequence. An observer might deliver its own alert promptly while sharing resources with the PBX in a way that affects call establishment. Conversely, call setup variation can arise without a corresponding change in detector computation. The accepted pilot retains the individual call observations and case medians so that these outcomes remain visible. Neither a lower enabled-mode median nor a higher one can be attributed to the detector from the nonrandomized WLAN blocks alone. The direction-changing external difference is especially useful evidence against a simple causal overhead narrative.

The sampling window also determines the interpretation of the resource figures. Excluding startup and offline extraction makes the reported values relevant to the selected active-traffic interval, but does not characterize installation, initialization or the entire analysis workflow. Process RSS and sampled CPU quantify particular observable resource measures. They do not isolate total device energy, kernel work or network cost. Thus the

pilot establishes that the selected processes were observed during functioning lab cases, rather than demonstrating that the full architecture satisfies an independently specified operational capacity requirement.

H3 combines latency, maintenance and acceptable overhead in one proposition. The evidence addresses these parts unevenly. The bounded latency observations support investigating native integration further; they do not establish maintenance effort across upgrades or acceptability under production load. A complete assessment would require a declared operating envelope and acceptance criteria before testing. Without those criteria, the present results can guide a deployment experiment but cannot determine which path an organization should adopt. This preserves the contribution of implementing both realizations without converting feasibility into a general deployment recommendation.

5.7 Research Questions and Hypotheses

Table 5.10 Evidence based answers and remaining scope

Question	Finding	Scope
RQ1	Confirmed failures, distinct targets and linked recovery/call events describe suspicion	Authorization remains ambiguous; production priors absent
RQ2 and H1	Coverage improves in the F-series; universally earlier first alerts are not shown	Inspected development traces and differing stage semantics
RQ3 and H2	Frozen ML gives the same category to every matched opposite-role pair	No demonstrated intent or false-alert improvement
RQ4 and H3	Later five-stage parity and lower native decision medians in a bounded pilot	Timing origins differ; causal overhead, load and maintainability unmeasured

The architecture supports interpretable review of protocol progression. It does not infer authorization from identical traffic. The evaluated runtime uses frozen rules and model coefficients, and the context layer conditions review on predeclared permissions. Autonomous online adaptation was not implemented or evaluated. Proposed mitigation remains distinct from the observation-only implementation.

5.8 Limitations and Exploratory Extensions

The development and fresh evaluation sets are small constructed workloads from one generator and PBX. The context experiment adds twelve frozen-protocol cases on one day, rather than a production sample. Permissions are laboratory administrator records. An

attacker operating within allowed policy can remain hidden, while an authorized recovery without observed permission can still alert. CDRs validate completion but do not supply a representative normal-call baseline. Different native and external timing origins constrain latency comparisons.

Four new REGISTER controls validate known single-account, known two-account shared-source and unused-identity patterns. They do not establish five legitimate accounts behind NAT, concurrent mixed sessions or packet-loss robustness. The public flooding benchmark remains a separate task. The new permission layer was evaluated through causal replay, so its live delivery, stability and operational enforcement are unmeasured. No source or threshold changed after the fresh capture batch.

5.9 Later Five Stage Deployment Pilot

The later B030 to B036 pilot extends the earlier authentication-only deployment work. Seven declared cases passed independent checks, with twenty-one answered six-second isolated calls. B030 is an authorized benign smoke case, while six primary cases contain eighteen calls. The enabled native and external paths reproduced the declared five online stage categories and frozen ML metadata tolerances. Table 5.11 reports descriptive packet-to-decision medians from this later pilot.

Table 5.11 Later native and external stage decision medians

Stage	Native ms	External ms	Observations per path
Reconnaissance	0.085	628.500	2
Authentication attack	1015.987	1907.184	2
Recovery review	4.709	394.017	2
Linked outbound attempt	0.090	522.112	6
Distinct call burst	0.091	640.665	2

The authentication row includes a one-second rejection grace. Recovery and other stages use different packet timing origins; native decision and logged observation availability also differ. Native call-setup medians of 60.539 and 43.350 ms exceeded the corresponding OFF medians of 15.710 and 12.900 ms in these nonrandomized WLAN blocks. External medians were 38.099 and 19.613 ms. Faster native alert decisions therefore do not establish zero call-setup cost or a causal overhead effect. B030 generated CALL_BURST despite

being authorized, and all four primary enabled cases received HIGHER ML priority. These are behaviour and deployment findings, not a fresh fraud-intent evaluation.

5.10 Fresh Permission Context Comparison

On 12 October 2026, C001 to C012 all passed the predeclared exact authentication-count, SIP completion, PCAP-drop, CDR-delta and cleanup gates. The batch contains fifty confirmed wrong-password dialogs and nine answered isolated calls. No case was replaced or excluded. Table 5.12 and Figure 5.3 show the same-case comparisons; Table 5.13 preserves the case-level decisions. The two assigned roles contain six cases each.

Table 5.12 Fresh case confusion counts and balanced accuracy

Method	TP	FP	TN	FN	Balanced accuracy	False alert rate
Auth 10	1	0	6	5	58.3%	0.0%
Auth 5	5	2	4	1	75.0%	33.3%
V6	5	2	4	1	75.0%	33.3%
V6 + context	5	1	5	1	83.3%	16.7%

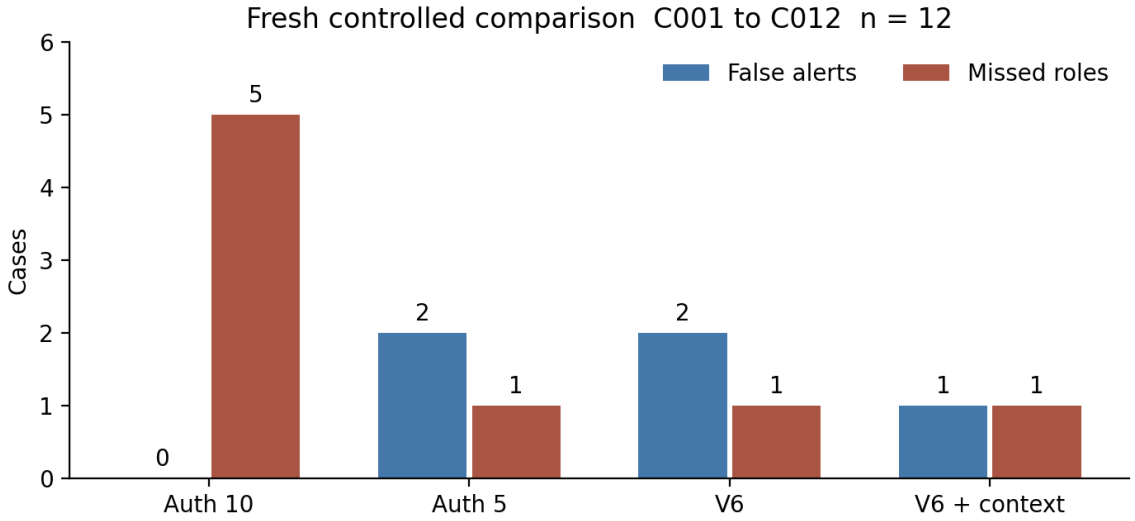


Figure 5.3 False alerts and missed assigned roles in twelve fresh cases

Table 5.13 Fresh case decisions from the common evaluator

Case	Role	Account	Destination	Fails	Auth 10	Auth 5	V6	Context
C001	B	1001	88001	0	0	0	0	0
C002	B	1002	88002	0	0	0	0	0
C003	B	1001	88001	6	0	1	1	0
C004	B	1002	88002	6	0	1	1	1

Case	Role	Account	Destination	Fails	Auth 10	Auth 5	V6	Context
C005	B	1001	No call	2	0	0	0	0
C006	B	1002	No call	2	0	0	0	0
C007	S	1001	88002	6	0	1	1	1
C008	S	1002	88001	6	0	1	1	1
C009	S	1001	88002	0	0	0	0	1
C010	S	1002	No call	10	1	1	1	1
C011	S	1001	88001	6	0	1	1	0
C012	S	1002	88002	6	0	1	1	1

B denotes the assigned benign role and S the scripted simulated-abuse role. A value of 1 means at least one qualifying online alert during the complete case, rather than proof of fraud. Context reduces the false-alert count from two to one: C003 receives authorized recovery review, while C004 retains actionable review because its recovery permission is unavailable. Context detects C009 at the forbidden INVITE despite no failed-authentication precursor. However, it misses C011, whose observed account, destination and maintenance permission match benign C003. Thus V6 and context miss different cases.

Context precision, recall and F1 are each 0.833 on this set. The balanced-accuracy increase from 0.750 to 0.833 describes one additional correct case out of twelve. It is not an ML improvement, a population estimate or evidence that the permissions reveal every unauthorized actor. C003/C011 deliberately demonstrate that identical policy-observable conditions can receive the same disposition despite opposite assigned roles.

5.10.1 Why the context comparison changes particular decisions

The aggregate context result is best explained through the cases whose disposition changes. C003 supplies a legitimate recovery sequence for an account with observed recovery permission. Suppressing an actionable interpretation in that case reduces the false-alert count. C004 provides the complementary condition: a benign assigned role without equivalent observed recovery permission. Its continued review is not an implementation inconsistency. It follows the stated rule that missing authorization evidence cannot be treated as affirmative permission. Together, the cases distinguish what the administrator intended from what the detector was actually given permission to infer.

C009 demonstrates a different source of detection. It has no failed-authentication precursor but attempts a destination outside the known account allowance. The added review comes from the destination policy check at INVITE, so it should not be attributed to the progression engine discovering an earlier compromise. This is an important architectural boundary. Combining components can broaden the set of observable violations while leaving the original component's capability unchanged. It also explains why complete-case recall can remain the same even when the identity of the missed simulated case changes.

C011 then exposes the limit of the added context. Its observed account, destination and recovery permission match the benign C003 conditions. The assigned simulated role is deliberately not a field that the detector can inspect. Giving those cases the same policy disposition is consistent with equal observable inputs. Recovering the role distinction by providing the experimental label would be circular and would cease to test detection. The remaining miss therefore identifies an information boundary: a permitted signalling sequence can still be assigned an unauthorized intention that is not expressed in the available policy evidence.

This reading prevents two opposite overinterpretations. The improvement is not trivial, because one benign case receives a more appropriate disposition and a direct forbidden-destination case becomes reviewable. It is also not a general solution to authorization, because permitted-policy abuse remains unresolved and missing context continues to generate review. The added layer makes decisions conditional on specified administrative facts. Its usefulness depends on those facts being available, independent of the label and sufficiently current for the event being assessed.

The numerical change is correspondingly narrow. Balanced accuracy increases by approximately 8.3 percentage points, reflecting one additional correct case among the twelve balanced cases. The false-alert proportion falls from two of six benign roles to one of six. These fractions describe the constructed cases and the frozen policy. They do not measure how often recovery permissions will be missing, stale or overly broad in an organization. Assessing that operational question would require a prospective record of permission administration as well as detector outputs, rather than scaling the laboratory percentage to an assumed population.

Table 5.14 Early warning coverage on five simulated role call cases

Method	Before INVITE	At INVITE	Missed	Median positive lead s
Auth 10	0/5	0	5	No warning
Auth 5	4/5	0	1	7.972
V6	4/5	0	1	2.989
V6 + context	2/5	2	1	2.995

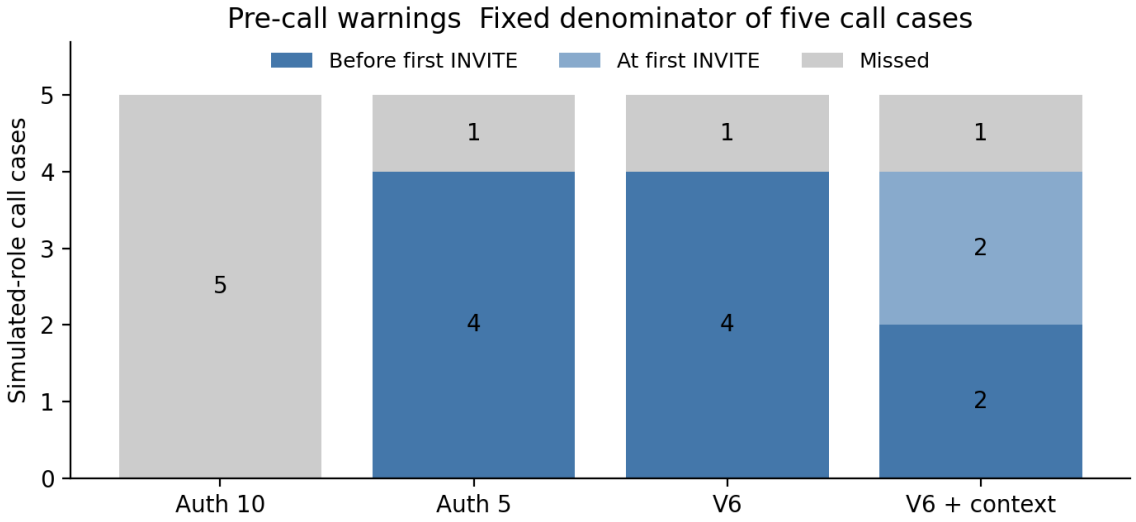


Figure 5.4 Pre call coverage with missed and at attempt cases retained

The five-failure simple baseline and V6 both warn before the first INVITE in four of five simulated-role call cases. Their positive lead medians are 7.972 s and 2.989 s respectively. Context warns early in two of five, with a positive lead median of 2.995 s, alerts at the first INVITE in C007 and C009, and misses C011. At-attempt alerts and the missed case remain explicit in Table 5.14 and Figure 5.4. The data support a precision and coverage tradeoff rather than a general claim that progression or context always warns earlier than simpler rules. Actual live availability of the new context layer was not measured.

5.10.2 Interpreting coverage together with warning lead

The context experiment shows why a median over successful early warnings must be accompanied by the cases that did not warn early. Its positive-lead median is close to V6's, but it is calculated from two early cases rather than four. Looking only at those medians would hide the reduction in opportunities for pre-call review. The two at-attempt alerts and the missed case retain their own categories because assigning them a convenient positive lead would change the question. The denominator of five simulated-role call cases is therefore central to the interpretation.

The five-failure baseline provides a useful challenge to the rationale for progression. On the tested calling cases, it accumulates enough confirmed failures earlier and has the same early-warning coverage as V6. A progression model needs subsequent evidence before it can express a more specific sequence relationship. That waiting can improve the explanation of why a case is suspicious while reducing the time available before the INVITE. The results suggest evaluating progression as an explanatory and corroborating layer, rather than assuming that additional stages must improve every timing outcome.

The context disposition introduces a further decision about when evidence is sufficient for action-oriented review. For an allowed recovery, waiting for a destination-policy violation can remove a benign early alert. It can also postpone a warning until the call attempt, or leave no violation to report when the destination is permitted. The observed tradeoff follows from the explicit policy rather than an unexplained loss of detector sensitivity. Reporting that mechanism allows a reader to assess whether the behaviour aligns with the study's intended review task.

No preferred operating point can be selected from this small experiment without defining the relative consequences of false alerts, delayed review and missed abuse. The study did not measure operator workload or intervention success, so those consequences are not assigned numerical costs here. Instead, it preserves complete-case confusion counts, pre-call coverage and positive lead as separate outcomes. Their joint interpretation supports an honest account of the prototype and supplies the endpoints for a later decision-focused evaluation.

5.11 Fresh REGISTER Controls and Reproducibility

Four separately declared REGISTER-only controls each sent six unauthenticated requests, with no INVITE, no CDR change and no PBX configuration change. All request and response transactions were independently verified in PBX-side captures. The original P002 timeout remains incomplete. P102 is new traffic using a revised send-only generator and PCAP response verification; it does not prove the original generator receive path has been repaired.

Table 5.15 Four new bounded REGISTER controls

Case	Targets	Distinct identities	Unknown requests	Diversity reviews
P101	1001 repeated	1	0	0
P102	1001 and 1002	2	0	0
P103	9001 repeated	1	6	0
P104	9001 to 9006	6	6	1

The two configured-account controls produce no diversity review. One unused identity also produces none. The six-unused-identity control reaches the five-distinct-target review threshold. This tests account diversity and known/unknown policy context, not malicious intent. Two configured accounts do not establish a five-user legitimate NAT baseline. The controls remain separate from the twelve role-labelled cases and are not pooled into their confusion matrices.

Baseline and evaluation freezes retain original code, dataset-split, model, policy and manifest hashes. All thirty-four historical PCAP hashes were checked without relabelling those observations as new tests. The twelve new PCAP hashes, final result hashes and deterministic predictions were rechecked. The portable reproduce_results.py script reproduces all twelve predictions and all four confusion matrices without network or PBX access. After traffic, the PBX had zero active calls, both temporary routes were absent and the native module was unloaded.

5.11.1 Reproducibility and the limits of repeated evidence

The evidence freeze serves two distinct purposes. Hashes identify which code, policy, manifests and captured inputs belong to the reported comparison. Reproduction of the saved predictions checks whether those retained materials produce the declared decisions. This makes accidental changes and post-result threshold adjustment more visible. It does not establish that the declared labels represent operational fraud, nor that an identical result will occur under another traffic distribution. Reproducibility strengthens the auditability of a claim while leaving the scope of that claim unchanged.

The registration controls similarly test particular mechanics rather than broad benign coverage. Known and unused identities exercise account context, and the six-unused-identity control exercises a diversity threshold. Their clean packet and CDR checks support those bounded observations. They do not supply independent additional benign roles for

the context confusion matrix. Pooling them with C001 to C012 would change the denominator and apparent class balance without adding equivalent authorization-labelled cases. Keeping the controls separate prevents a functionality check from inflating a discrimination estimate.

Preserving the original P002 timeout is part of the same logic. P102 demonstrates that new send-only traffic can be verified through captured responses; it does not retrospectively repair a failed receive path. An evidence archive is more informative when failed or incomplete attempts remain traceable alongside replacements. This enables a later reader to distinguish a tested protocol change from a corrected historical observation. The result is a bounded, inspectable experimental record, rather than a collection containing only the final successful outputs.

Chapter 6 Conclusion and Future Work

6.1 Conclusions

The research produced a reproducible SIP progression prototype with protocol-aware authentication, entity-linked recovery suspicion, distinct-call burst events, causal ML review priority and two bounded deployment realizations. Independent packets, authentication logs and answered CDRs make its lab behaviour auditable.

The research establishes interpretable progression with an explicit authorization ambiguity boundary. The new context layer improves balanced accuracy from 75.0% to 83.3% on twelve fresh controlled role-labelled cases by reducing one false alert and changing which case is missed. It also reduces pre-call warning coverage from four of five to two of five simulated-role call cases. The five-failure baseline warns earlier than V6 in the comparable call cases. These results qualify the early-fraud claim and show why accuracy, permission evidence and warning time must be reported together.

The later native and external pilot covers five online stages and has lower native decision medians on this Pi, while call-setup results remain variable and noncausal. H1 is not supported as a universal earlier-warning claim. H2 is unsupported for the frozen ML score; the separate context result cannot be attributed to ML. H3 has bounded latency and stage-parity evidence, while maintainability, acceptable production overhead and safe mitigation remain unestablished.

6.1.1 Scope of the final contribution

The architectural contribution is the explicit separation of protocol evidence, progression state, learned review priority and independent permission disposition. The experiments show why these outputs should not be collapsed into one claim of proven fraud. A confirmed authentication failure identifies a rejected transaction; a recovery stage links events; a model category orders review; and a permission check relates the event to a declared allowance. Each answers a different question. The thesis contributes an implemented way to preserve those questions within an auditable pipeline and demonstrates cases in which their answers diverge.

The evaluated runtime uses frozen thresholds and coefficients. Its context layer conditions review on predeclared permissions; autonomous baseline learning and online adaptation

were not implemented or evaluated. A policy-conditioned disposition can change when independent permission facts differ, but that is not evidence of an update mechanism learning from new observations. This distinction preserves the approved title while defining the additional mechanism and prospective tests needed before making a stronger adaptation claim.

The resulting thesis conclusion is therefore substantive even where the hypotheses are unsupported. The study establishes a functioning observation prototype, supplies reproducible comparisons and identifies information and timing boundaries that constrain early fraud review. It also demonstrates that a simple baseline can outperform a richer detector on one practical timing endpoint. These findings define what was learned from building and testing the architecture; they do not depend on reporting every anticipated improvement as achieved.

6.2 Objective Coverage

Table 6.1 Coverage of the research objectives

Objective	Implemented and evaluated	Remaining qualification
O1 indicators	Confirmed auth semantics, target diversity and recovery/call linkage	No universal intent separator or production prior
O2 progression	Frozen V6 plus separate permission-conditioned review and twelve fresh cases	Allowed-policy hidden roles remain ambiguous; early-warning tradeoff
O3 deployment	External and native five-stage observers; bounded live pilot	Production generality, throughput and maintenance unmeasured
O4 ML refinement	Frozen causal model and fresh matched evaluation	Implementation complete; claimed improvement not demonstrated
O5 evaluation	Common confusion, event-clock lead times, live pilots and reproducible freezes	Production baseline, causal load and mitigation not evaluated

Table 6.1 maps the five research objectives stated in Chapter 1 to the implementation and evaluation. It distinguishes completing a planned investigation from obtaining the expected performance improvement. A negative result can answer a research question without validating the original hypothesis; objective coverage is therefore reported with its remaining qualification.

6.2.1 Relationship between objective coverage and expected benefit

O1 is addressed through the implemented indicators and their evaluated boundaries. The study identifies confirmed rejection, target diversity, recovery and linked calling as useful descriptions of progression. Its matched cases also show that useful indicators need not be sufficient identifiers of unauthorized intent. That distinction is an answer to the objective, rather than a reason to omit ambiguous observations. The contribution is strongest when each indicator is described in terms of what the captured event establishes and what remains dependent on independent context.

The other objectives separate implementation from expected benefit. O2 is supported by explicit entity histories and ordered stage decisions, without establishing calibrated operational fraud risk. O3 has bounded native and external implementation evidence, while maintenance and causal overhead remain unresolved. O4 was investigated through a frozen learning experiment whose proposed improvement was not demonstrated. O5 brings controlled traffic, packet and call checks, descriptive resources and complete-case metrics together, while leaving a representative production baseline, load robustness and safe intervention unmeasured. This mapping records the evidence received by each planned question rather than assuming that performing an experiment confirms its anticipated outcome.

6.3 Future Work

Future evaluation should obtain independently administered production permissions and recovery records, collect consented normal behaviour from multiple entities and networks, and prospectively test frozen candidates on new days and concurrent sessions. The present two-account control should be extended to legitimate larger NAT groups. SIP-to-CDR identity linkage and retransmission controls need broader validation before records become entity-level behavioural priors.

The implemented native stage pilot should next undergo repeated matched load, stability, upgrade and recovery tests. The context layer needs live delivery and operator-disposition testing. A mitigation prototype should be evaluated separately for false-positive disruption. These extensions remain future work; the present conclusions apply to an auditable controlled prototype and its measured evidence.

6.3.1 Design of the next validation study

A follow-up study should first define its primary decision task. If the task is pre-call administrator review, the protocol should specify which events count as qualifying warnings, when those warnings become available and which calling boundary defines the lead. If the task is destination-policy enforcement, at-attempt violations should be evaluated separately. This prevents a later analysis from switching between intent classification, suspicious-stage recognition and policy compliance according to the most favourable result. A frozen baseline set should accompany the progression and context candidates throughout the new batch.

The next permission evaluation should also preserve the independence demonstrated by the laboratory design while making the records operationally credible. Permission and recovery records should be administered before traffic observation by a process separate from prediction and lab-role assignment. The protocol should declare how absent, expired and conflicting records are handled. Cases with allowed-policy abuse are necessary because they challenge the information boundary exposed by C011. Ordinary authorized recovery with incomplete records is equally necessary because it tests whether the review workflow creates an excessive burden for legitimate users.

For the deployment comparison, a planned series should repeat matched workloads across multiple days and vary mode order rather than relying on one sequence of WLAN blocks. It should distinguish packet availability, normalized-event arrival, rule decision, alert availability and call setup. Whole-path and component measurements can then be interpreted without assuming identical endpoints. Load, concurrent accounts and long-running state should be declared dimensions of the workload. The study should establish the tolerable impact before observing results, so that acceptable overhead becomes a testable statement rather than a retrospective description.

A later adaptation experiment would require an implemented update rule in addition to the present frozen model. The rule would need declared inputs, update timing and safeguards against using future outcomes during earlier decisions. Evaluation should compare the frozen and adapting candidates on the same prospective sequence while retaining each version and decision history. The question would then be whether the specified update improves a declared endpoint under changing conditions. Such a study would test runtime

adaptation directly, instead of using successive research versions as evidence that an operating detector adapts.

An intervention study should measure operator understanding, resolution of ambiguous cases and correction of erroneous dispositions before adding automatic restrictions. It should then assess disruption to legitimate calling, recovery, override and audit requirements. The present prototype supplies controlled evidence for designing those tests; it does not establish intervention outcomes.

References

[1] J. Rosenberg et al., “SIP: Session Initiation Protocol,” RFC 3261, IETF, Jun. 2002, doi: 10.17487/RFC3261.

[2] Asterisk Project, “Overview - Asterisk REST Interface (ARI),” Asterisk Documentation. [Online]. Available: https://docs.asterisk.org/Configuration/Interfaces/Asterisk-REST-Interface-ARI/. [Accessed: 12-Oct-2026].

[3] Asterisk Project, “CDR Specification,” Asterisk Documentation. [Online]. Available: https://docs.asterisk.org/Configuration/Reporting/Call-Detail-Records-CDR/CDR-Specification/. [Accessed: 12-Oct-2026].

[4] Asterisk Project, “Overview - Reporting,” Asterisk Documentation. [Online]. Available: https://docs.asterisk.org/Configuration/Reporting/. [Accessed: 12-Oct-2026].

[5] L. Manunza, S. Marseglia, and S. P. Romano, “Kerberos: A real-time fraud detection system for IMS-enabled VoIP networks,” Journal of Network and Computer Applications, vol. 80, pp. 22–34, Feb. 2017, doi: 10.1016/j.jnca.2016.12.018.

[6] D. Seo, H. Lee, and E. Nuwere, “SIPAD: SIP–VoIP anomaly detection using a stateful rule tree,” Computer Communications, vol. 36, no. 5, pp. 562–574, Mar. 2013, doi: 10.1016/j.comcom.2012.12.004.

[7] S. Chiappetta, C. Mazzariello, R. Presta, and S. P. Romano, “An anomaly-based approach to the analysis of the social behavior of VoIP users,” Computer Networks, vol. 57, no. 6, pp. 1545–1559, Apr. 2013, doi: 10.1016/j.comnet.2013.02.009.

[8] O. S. Younes, “A hybrid deep learning model for detecting DDoS flooding attacks in SIP-based systems,” Computer Networks, vol. 240, Art. no. 110146, Feb. 2024, doi: 10.1016/j.comnet.2023.110146.

[9] D. Golait and N. Hubballi, “Detecting anomalous behavior in VoIP systems: A discrete event system modeling,” IEEE Transactions on Information Forensics and Security, vol. 12, no. 3, pp. 730–745, Mar. 2017, doi: 10.1109/TIFS.2016.2632071.

[10] X. Hu et al., “BTG: A bridge to graph machine learning in telecommunications fraud detection,” Future Generation Computer Systems, vol. 137, pp. 274–287, Dec. 2022, doi: 10.1016/j.future.2022.07.020.

[11] L. Ren et al., “Dynamic graph neural network-based fraud detectors against collaborative fraudsters,” Knowledge-Based Systems, vol. 278, Art. no. 110888, Oct. 2023, doi: 10.1016/j.knosys.2023.110888.

[12] K. Dassouki, H. Safa, M. Nassar, and A. Hijazi, “Protecting from cloud-based SIP flooding attacks by leveraging temporal and structural fingerprints,” Computers & Security, vol. 70, pp. 618–633, 2017, doi: 10.1016/j.cose.2017.08.003.

[13] H. Sengar, D. Wijesekera, H. Wang, and S. Jajodia, “VoIP intrusion detection through interacting protocol state machines,” in Proc. International Conference on Dependable Systems and Networks (DSN), 2006, pp. 393–402, doi: 10.1109/DSN.2006.73.

[14] W. Nazih, W. S. Elkilani, H. Dhahri, and T. Abdelkader, “Survey of countering DoS/DDoS attacks on SIP based VoIP networks,” Electronics, vol. 9, no. 11, Art. no. 1827, 2020, doi: 10.3390/electronics9111827.

[15] A. Aziz, Real-time Detection & Mitigation of SIP-based VoIP Toll Fraud Attacks, Ph.D. dissertation, University of Duisburg-Essen, Essen, Germany, 2025. [Online]. Available: https://duepublico2.uni-due.de/servlets/MCRFileNodeServlet/duepublico_derivate_00082524/Diss_Aziz.pdf

[16] A. Aziz, D. Hoffstadt, E. Rathgeb, and T. Dreibholz, “A Distributed Infrastructure to Analyse SIP Attacks in the Internet,” in Proc. IFIP Networking Conference, Trondheim, Norway, 2014, doi: 10.1109/IFIPNetworking.2014.6857088.

[17] T. Cejka, V. Bartos, L. Truxa, and H. Kubatova, “Using application-aware flow monitoring for SIP fraud detection,” in Intelligent Mechanisms for Network Configuration and Security, vol. 9122, Cham: Springer, 2015, pp. 87–99, doi: 10.1007/978-3-319-20034-7_10.

[18] T. Kapourniotis, T. Dagiuklas, C. G. Polyzos, and P. Alefragkis, “Scam and fraud detection in VoIP networks: Analysis and countermeasures using user profiling,” in 2011 50th FITCE Congress, 2011, pp. 1–5, doi: 10.1109/FITCE.2011.6133427.

[19] K. M. U. P. Kosgoda, “SIP toll fraud research,” GitHub repository, evidence snapshot d7efaefb693d29b6a189a9eddce819e1767630ab, Nov. 2026. [Online]. Available: https://github.com/uchitha1996/sip-toll-fraud-research-ms24913188/tree/d7efaefb693d29b6a189a9eddce819e1767630ab. [Accessed: 3-Nov-2026].

Appendices

A Progression Logic and Causal Scoring

The following pseudocode summarizes the implementation. Full Python, SIPp XML and C module sources are retained in the experiment repository rather than reproduced in the thesis body.

```
for each normalized event in event-time order:
    prune histories by source IP and account
    add only confirmed digest rejection events
    on successful REGISTER with at least five failures in 120 seconds:
        emit SUSPECTED_COMPROMISE
        score only features available at this event
        attach LOWER REVIEW or HIGHER priority without suppressing rule evidence
    on a linked distinct lab INVITE within 120 seconds:
        emit SUSPECTED_OUTBOUND_ATTEMPT
    on the third distinct call within 60 seconds:
        emit CALL_BURST
```

B Frozen Model Configuration

Table B.1 Frozen logistic feature scaling and coefficients

Feature	Mean	Scale	Coefficient
failures_120s	6.500000	1.565248	0.177752
peak_failures_10s	4.700000	0.900000	0.123668
failure_span_s	12.960280	5.638711	0.127886
first_failure_to_success_s	16.051260	5.650309	0.155683

Intercept: 0.003881613. Priority cut points: 0.4 and 0.6. Training episodes: D007, D008, D009, D010, D011, D019, D020, D021, D022, D023. The score is evaluated only at the eligible successful registration event.

C Evidence and Source Index

The canonical root is /home/astrix/sip-fraud-research on Astrix-lab. Raw captures, manifests, logs, CDR snapshots and independent checks are retained. Dataset families overlap where a capture is replayed, so their sizes must not be added as independent samples.

The public GitHub research archive [19] preserves the main PBX source, models, results and supporting documents at commit d7efaefb693d29b6a189a9eddce819e1767630ab. Its inventory identifies authentication-bearing originals retained outside GitHub, together with the generator and public benchmark material outside this snapshot.

Table C.1 Canonical evidence directories

Result family	Relative directory
Registered F-series	datasets/f-series-evaluation/20260930T094922Z
Archived ordering audit	datasets/online-prototype-audit-20261001
Fresh causal evaluation	datasets/causal-ml-holdout-20261001
Live causal integration	datasets/live-ml-20261001/B016
Auth delivery pilot	datasets/deployment-auth-comparison-20261002
Call pilot and failed capture record	datasets/deployment-call-comparison-20261002
Replacement block	datasets/deployment-call-comparison-replacement-20261002
Raw call captures	datasets/burst-lab-20261001/development
Full-stage deployment	datasets/full-stage-deployment-comparison-20261002
New policy, code, metrics and captures	accelerated-20261012
Portable deterministic replay	accelerated-20261012/reproduce_results.py

Key sources include candidate_v5_replay.py, progression_v6_development.py, external_event_service.py, external_event_service_ml.py, lab_burst_runner.py, verify_burst_run.py and the separate deployment measurement and audit scripts. The shared-auth external collector deliberately does not forward INVITE events. The module binary remains installed but was unloaded after validation.

D Reproducibility Checksums

The links below open the exact files in the GitHub evidence snapshot cited in [19]. Each SHA-256 checksum identifies the corresponding file version and supports integrity verification after download.

Frozen V5 detector and replay source
GitHub file: candidate_v5_replay.py
SHA-256: e23ffd00ef931c23b1e2a4e9b0fccb6731d57025f94dbdc3a9045a75de825004

Frozen V6 progression detector source
GitHub file: progression_v6_development.py
SHA-256: c4b9231a89a815e93f1264119e229df1a563d574ba4b6a7e357d8125983eb2b4

Causal machine learning model
GitHub file: frozen_model.json
SHA-256: ece43b48eb1d98115c2796735c67fc80589f8ff85d51765e78d373e3079ee30d

Causal holdout evaluation manifest
GitHub file: causal_ml_holdout_manifest_20261001.json
SHA-256: 652e68d674fa5bac4909cc407206bcb991b60301bba8aab75eef145790afdaa5

Authentication comparison manifest
GitHub file: manifest.json
SHA-256: 13dd84d26470f1f063b9a2734118b490ba318e746fe00e2c521268457a2cf78d

Combined call comparison summary
GitHub file: combined_summary.json
SHA-256: 712001679d2f0aeee31b471b71b3e006ee283ad9f627381fd36ad9003e31e9df